



THE EDUCATIONAL TOOLS AND SUPPORT SERVICES

SOC 2 - TYPE 2 REPORT

***Independent Service Auditor's Report
On a Service Organization's Description of
Its System and the Suitability of the Design
and Operating Effectiveness of Its Controls
Relevant to Security and Confidentiality***

For the Period October 1, 2024 to September 30, 2025



INDEPENDENT SERVICE AUDITOR'S REPORT

TABLE OF CONTENTS

SECTION 1	INDEPENDENT SERVICE AUDITOR'S REPORT	1
SECTION 2	MANAGEMENT ASSERTION OF PROGRESS LEARNING	6
SECTION 3	DESCRIPTION OF THE SERVICE ORGANIZATION'S SYSTEM	8
	OVERVIEW OF OPERATIONS	9
	Company Background	9
	Description of Services Provided	9
	Disaster Recovery	15
	CONTROL ENVIRONMENT	16
	Integrity and Ethical Values	16
	Commitment to Competence	16
	Board of Directors' Participation	17
	Management's Philosophy and Operating Style	17
	Organization Structure and Assignment of Authority and Responsibility	18
	Human Resource Policies and Practices	18
	RISK ASSESSMENT	20
	CONTROL OBJECTIVES AND RELATED CONTROL ACTIVITIES	22
	MONITORING	22
	INFORMATION AND COMMUNICATION SYSTEMS	24
	Information Systems	24
	Communication Systems	24
	COMPLEMENTARY CONTROLS	25
SECTION 4	TESTING MATRICES	28
	MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY	
	Control Environment	29
	Communication and Information	37
	Risk Assessment	47
	Monitoring Activities	53
	Control Activities	61
	Logical and Physical Access Controls	78
	System Operations	103
	Change Management	112
	Risk Mitigation	120
	MATRIX 2 ADDITIONAL CRITERIA FOR CONFIDENTIALITY	124

SECTION 1

INDEPENDENT SERVICE AUDITOR'S REPORT

**Independent Service Auditor's Report on a Description of a Service Organization's System
and the Suitability of the Design and Operating Effectiveness of Controls
Relevant to Security and Confidentiality**

To: Progress Learning, LLC,

Scope

We have examined Progress Learning, LLC's (PROGRESS LEARNING) accompanying description of its educational tools and support services and systems found in Section 3 titled "Description of the Service Organization's System Provided by Progress Learning Management" throughout the period October 1, 2024 to September 30, 2025 (description) based on the criteria for a description of a service organization's system set forth in *DC 200, 2018 Description Criteria for a Description of a Service Organization's System in a SOC 2® Report* (AICPA, *Description Criteria*) (description criteria), and the suitability of the design and operating effectiveness of controls stated in the description throughout the period October 1, 2024 to September 30, 2025, to provide reasonable assurance that PROGRESS LEARNING's service commitments and system requirements were achieved based on the trust services criteria relevant to security and confidentiality (applicable trust services criteria) set forth in *TSP 100, 2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy* (AICPA, *Trust Services Criteria*).

PROGRESS LEARNING uses a third-party data center (subservice organization) to house its critical production computer servers, applications and networking equipment. The description indicates that complementary subservice organization controls that are suitably designed and operating effectively are necessary, along with controls at PROGRESS LEARNING, to achieve PROGRESS LEARNING's service commitments and system requirements based on the applicable trust services criteria. The description presents PROGRESS LEARNING's controls, the applicable trust services criteria, and the types of complementary subservice organization controls assumed in the design of PROGRESS LEARNING's controls. The description does not disclose the actual controls at the subservice organization. Our examination did not include the services provided by the subservice organization, and we have not evaluated the suitability of the design or operating effectiveness of such complementary subservice organization controls.

The description indicates that certain complementary user entity controls that are suitably designed and operating effectively are necessary, along with controls at PROGRESS LEARNING, to achieve PROGRESS LEARNING's service commitments and system requirements based on the applicable trust services criteria. The description presents PROGRESS LEARNING's controls, the applicable trust services criteria, and the complementary user entity controls assumed in the design of PROGRESS LEARNING's controls. Our examination did not include such complementary user entity controls, and we have not evaluated the suitability of the design or operating effectiveness of such controls.

Service Organization's Responsibilities

PROGRESS LEARNING is responsible for its service commitments and system requirements and for designing, implementing, and operating effective controls within the system to provide reasonable assurance that PROGRESS LEARNING's service commitments and system requirements were achieved. In Section 2, PROGRESS LEARNING has provided the accompanying assertion titled "Management Assertion of Progress Learning" (assertion) about the description and the suitability of the design and operating effectiveness of controls stated therein. PROGRESS LEARNING is also responsible for preparing the description and assertion, including

the completeness, accuracy, and method of presentation of the description and assertion; providing the services covered by the description; selecting the applicable trust services criteria and stating the related controls in the description; and identifying the risks that threaten the achievement of the service organization's service commitments and system requirements.

Service Auditor's Responsibilities

Our responsibility is to express an opinion on the description and on the suitability of the design and operating effectiveness of controls stated in the description based on our examination. Our examination was conducted in accordance with attestation standards established by the American Institute of Certified Public Accountants. Those standards require that we plan and perform our examination to obtain reasonable assurance about whether, in all material respects, the description is presented in accordance with the description criteria and the controls stated therein were suitably designed and operated effectively to provide reasonable assurance that the service organization's service commitments and system requirements were achieved based on the applicable trust services criteria. We believe that the evidence we obtained is sufficient and appropriate to provide a reasonable basis for our opinion.

An examination of a description of a service organization's system and the suitability of the design and operating effectiveness of controls involves —

- obtaining an understanding of the system and the service organization's service commitments and system requirements.
- assessing the risks that the description is not presented in accordance with the description criteria and that controls were not suitably designed or did not operate effectively.
- performing procedures to obtain evidence about whether the description is presented in accordance with the description criteria.
- performing procedures to obtain evidence about whether controls stated in the description were suitably designed to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the applicable trust services criteria.
- testing the operating effectiveness of controls stated in the description to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the applicable trust services criteria.
- evaluating the overall presentation of the description.

Our examination also included performing such other procedures as we considered necessary in the circumstances.

We are required to be independent and to meet our other ethical responsibilities in accordance with relevant ethical requirements relating to the examination engagement.

Inherent Limitations

The description is prepared to meet the common needs of a broad range of report users and may not, therefore, include every aspect of the system that individual report users may consider important to meet their informational needs. There are inherent limitations in the effectiveness of any system of internal control, including the possibility of human error and the circumvention of controls. Because of their nature, controls may not always operate effectively to provide reasonable assurance that the service organization's service commitments and system requirements are achieved based on the applicable trust services criteria. Also, the projection to the future of any

conclusions about the suitability of the design and operating effectiveness of controls is subject to the risk that controls may become inadequate because of changes in conditions or that the degree of compliance with the policies or procedures may deteriorate.

Description of Tests of Controls

The specific controls we tested and the nature, timing, and results of those tests are listed in Section 4, titled "Testing Matrices" of this report.

Opinion

In our opinion, in all material respects —

- a. the description presents PROGRESS LEARNING's educational tools and support services and systems that were designed and implemented throughout the period October 1, 2024 to September 30, 2025 in accordance with the description criteria.
- b. the controls stated in the description were suitably designed throughout the period October 1, 2024 to September 30, 2025 to provide reasonable assurance that PROGRESS LEARNING's service commitments and system requirements would be achieved based on the applicable trust services criteria, if its controls operated effectively throughout that period, and if subservice organizations applied the complementary subservice organization controls and user entities applied the complementary user entity controls assumed in the design of PROGRESS LEARNING's controls throughout that period.
- c. the controls stated in the description operated effectively throughout the period October 1, 2024 to September 30, 2025 to provide reasonable assurance that PROGRESS LEARNING's service commitments and system requirements were achieved based on the applicable trust services criteria, if complementary subservice organization controls and complementary user entity controls assumed in the design of PROGRESS LEARNING's controls operated effectively throughout that period.

Restricted Use

This report, including the description of tests of controls and results thereof in Section 4, is intended solely for the information and use of management of PROGRESS LEARNING; user entities of PROGRESS LEARNING's educational tools and support services and systems during some or all of the period October 1, 2024 to September 30, 2025; business partners of PROGRESS LEARNING subject to risks arising from interactions with the educational tools and support services and systems; practitioners providing services to such user entities and business partners; prospective user entities and business partners; and regulators who have sufficient knowledge and understanding of the following:

- The nature of the service provided by the service organization.
- How the service organization's system interacts with user entities, business partners, subservice organizations, and other parties.
- Internal control and its limitations.
- Complementary subservice organization controls and complementary user entity controls and how those controls interact with the controls at the service organization to achieve the service organization's service commitments and system requirements.
- User entity responsibilities and how they may affect the user entity's ability to effectively use the service organization's services.

- The applicable trust services criteria.
- The risks that may threaten the achievement of the service organization's service commitments and system requirements and how controls address those risks.

This report is not intended to be, and should not be, used by anyone other than these specified parties.

The Moore Group CPA, LLC

Nashua, NH
October 3, 2025

SECTION 2

MANAGEMENT ASSERTION OF PROGRESS LEARNING

MANAGEMENT ASSERTION OF PROGRESS LEARNING

We have prepared the accompanying description of Progress Learning, LLC's (PROGRESS LEARNING) educational tools and support services and systems titled "Description of the Service Organization's System Provided by Progress Learning Management" throughout the period October 1, 2024 to September 30, 2025 (description) based on the criteria for a description of a service organization's system set forth in *DC 200, 2018 Description Criteria for a Description of a Service Organization's System in a SOC 2® Report (AICPA, Description Criteria)*, (description criteria). The description is intended to provide report users with information about the educational tools and support services and systems that may be useful when assessing the risks arising from interactions with PROGRESS LEARNING's system, particularly information about system controls that PROGRESS LEARNING has designed, implemented, and operated to provide reasonable assurance that its service commitments and system requirements were achieved based on the trust services criteria relevant to security and confidentiality (applicable trust services criteria) set forth in *TSP 100, 2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy (AICPA, Trust Services Criteria)*.

PROGRESS LEARNING uses a third-party data center (subservice organization) to house its critical production computer servers, applications and networking equipment. The description indicates that complementary subservice organization controls that are suitably designed and operating effectively are necessary, along with controls at PROGRESS LEARNING, to achieve PROGRESS LEARNING's service commitments and system requirements based on the applicable trust services criteria. The description presents PROGRESS LEARNING's controls, the applicable trust services criteria, and the types of complementary subservice organization controls assumed in the design of PROGRESS LEARNING's controls. The description does not disclose the actual controls at the subservice organization.

The description indicates that complementary user entity controls that are suitably designed and operating effectively are necessary, along with controls at PROGRESS LEARNING, to achieve PROGRESS LEARNING's service commitments and system requirements based on the applicable trust services criteria. The description presents the service organization's controls, the applicable trust services criteria, and the complementary user entity controls assumed in the design of the service organization's controls.

We confirm, to the best of our knowledge and belief, that -

- 1) The description presents PROGRESS LEARNING's educational tools and support services and systems that were designed and implemented throughout the period October 1, 2024 to September 30, 2025 in accordance with the description criteria.
- 2) The controls stated in the description were suitably designed throughout the period October 1, 2024 to September 30, 2025 to provide reasonable assurance that PROGRESS LEARNING's service commitments and system requirements would be achieved based on the applicable trust services criteria, if its controls operated effectively throughout that period, and if the subservice organizations applied the complementary subservice organization controls and user entities applied the complementary user entity controls assumed in the design of PROGRESS LEARNING's controls throughout that period.
- 3) The controls stated in the description operated effectively throughout the period October 1, 2024 to September 30, 2025 to provide reasonable assurance that PROGRESS LEARNING's service commitments and system requirements were achieved based on the applicable trust services criteria, if complementary subservice organization controls and complementary user entity controls assumed in the design of PROGRESS LEARNING's controls operated effectively throughout that period.

SECTION 3

DESCRIPTION OF THE SERVICE ORGANIZATION'S SYSTEM PROVIDED BY PROGRESS LEARNING MANAGEMENT

OVERVIEW OF OPERATIONS

Company Background

Progress Learning, LLC (PROGRESS LEARNING) provides educational tools and support services that help students master state standards by empowering educators with personalized tools and support. PROGRESS LEARNING works to make the lives of teachers easier and makes sure all students, no matter the speed of mastery, are given the opportunity to grow and feel excited about being in the classroom. PROGRESS LEARNING is headquartered in Atlanta, GA, with a second office location in Plano, TX.

Scope

The scope of this SOC report includes an assessment of the general organizational and information technology controls supporting the educational tools and support services and systems of PROGRESS LEARNING. The scope explicitly excludes any evaluation, assurance, or commentary regarding the entity's banking operations, fraud prevention or detection mechanisms, cash receipts or disbursement processes, accounting functions, or any other internal or external financial responsibilities of PROGRESS LEARNING. In addition, this report does not constitute an audit, review, or examination of financial statements or financial information, nor does it provide any form of assurance regarding the integrity, accuracy, or completeness of financial reporting, anti-fraud measures, or compliance with financial regulations. The responsibility for the adequacy and effectiveness of controls related to financial operations, fraud prevention or detection, and regulatory compliance remains solely with PROGRESS LEARNING.

Users of this report should not rely on it as a substitute for performing their own due diligence or for obtaining other audits or assessments relevant to financial, operational, or regulatory matters outside the defined scope.

Description of Services Provided

PROGRESS LEARNING offers the following data-driven educational tools and support services:

Progress Learning for Elementary School

PROGRESS LEARNING provides award-winning online assessments to help prepare elementary and intermediate students for state testing. PROGRESS LEARNING's program conforms 100% to state standards and provides a highly engaging and amazingly effective way for students to master all their state standards for each grade level and tier. PROGRESS LEARNING is a highly effective Tier 1 solution for practice, instruction, and assessment.

Liftoff Adaptive Intervention for Math and Reading

Liftoff is an adaptive intervention program for grades 2 through 8 that supports instruction by finding students' learning levels through diagnostic assessments and targeting specific academic standards in vertical alignment where learning gaps may have occurred. The program provides practice and instruction in a highly engaging learning environment and motivates students to master topics by providing both instant and long-term rewards.

Progress Learning for Middle School

The Progress Learning Middle School Platform is a simple and effective way to supplement instruction with high-quality, 100% standards-aligned practice items. PROGRESS LEARNING uses a special combination of personalized learning and interactive gaming elements inspired by Education Galaxy to keep students engaged and motivated with learning as they grow up! With thousands of high-quality practice items, easy-to-use assessments, and progress monitoring, proven results are seen again and again.

Progress Learning for High School

The Progress Learning High School Platform is a simple and effective way to supplement instruction with high-quality, 100% standards-aligned practice items. PROGRESS LEARNING provides a detailed alignment to every single standard so that educators can feel confident their students are working with the best possible materials to prepare them for their biggest tests yet – including national tests like the SAT and ACT. With thousands of high-quality practice items, easy-to-use assessments, and progress monitoring, proven results are seen again and again.

Horizon Education for High School

Horizon Education is a powerful PSAT, SAT, PreACT, and ACT test prep program designed to provide equitable access to all students, no matter their background or socio-economic status. PROGRESS LEARNING does this by partnering directly with high schools and equipping them with SAT and ACT readiness courses, diagnostic PSAT, SAT, PreACT or ACT-aligned assessments, and detailed score report and analysis. PROGRESS LEARNING levels the playing field even further with professional development training which turns any teacher into a SAT/ACT Master Instructor.

Principal Service Commitments and System Requirements

PROGRESS LEARNING makes service commitments to its customers and has established system requirements as part of the educational tools and support services. Some of these commitments are principal to the performance of the service and relate to the applicable trust services criteria. PROGRESS LEARNING is responsible for its service commitments and system requirements and for designing, implementing, and operating effective controls within the system to provide reasonable assurance that PROGRESS LEARNING's service commitments and system requirements are achieved.

Service commitments to customers are documented and communicated in PROGRESS LEARNING's policies and procedures, system design documentation, customer agreements, or other written company materials provided to user entities as well as in the description of the service offering provided online. Service commitments include, but are not limited to, the following:

- **Security:** PROGRESS LEARNING has made commitments related to a secure information technology control environment and complying with relevant laws and regulations. These commitments are addressed through measures including data encryption, authentication mechanisms, and other relevant security controls.
- **Confidentiality:** PROGRESS LEARNING has made commitments related to maintaining the confidentiality of customers' data through data classification policies, data encryption and other relevant security controls.

PROGRESS LEARNING has established operational requirements that support the achievement of service commitments, relevant laws and regulations, and other system requirements. Such requirements are communicated in its system policies and procedures, system design documentation, and customer agreements. Information security policies define an organization-wide approach to how systems and data are protected. These include policies around how the service is designed and developed, how the system is operated, how the internal business systems and networks are managed, and how employees are hired and trained. In addition to these policies, standard operating procedures have been documented on how to carry out specific manual and automated processes required in the operation and development of various PROGRESS LEARNING services.

Components of the System

System Boundaries

A system is designed, implemented, and operated to achieve specific business objectives in accordance with management-specified requirements. The purpose of the system description is to delineate the boundaries of the system, which includes the description of services and the components of infrastructure, software, people, procedures, and data.

The components of the system used to provide the services are as follows:

Infrastructure

PROGRESS LEARNING's main corporate office is located in Atlanta, GA.

Subservice Organization - For colocation of critical production servers and systems, PROGRESS LEARNING utilizes a secure third-party data center, Amazon Web Services (AWS). AWS had a SOC 2 Type 2 audit for the review period April 1, 2024 to March 31, 2025. The scope of this audit does not include the controls of AWS.

The cloud environment infrastructure has redundancy at all levels. Redundant layers at the edge (routers and firewalls), redundant at the core (switching), redundancy within the hosts, and redundant backend storage. Redundant architecture exists such that data is replicated in real-time to at least two geographically dispersed data centers. The data centers are connected through multiple encrypted network links and interfaces.

Critical web servers are in AWS EC2 (Elastic Compute Cloud) environment and utilize its Elastic Load Balancer (ELB) offering. The system is highly scalable and exists in multiple availability zones (AZs) for geographical redundancy. The server instances are in their own VPC (Virtual Private Cloud) such that they are logically isolated from other virtual networks in the AWS cloud.

The server and network hardware layer is managed by AWS. The Virtual Private Cloud network (ie: logical administrative access to creating and managing production servers) is managed by PROGRESS LEARNING via IAM (Identity and Access Management). Internal PROGRESS LEARNING administrative access to servers is made over secure VPN connections.

AWS CloudWatch is utilized by PROGRESS LEARNING to gain system-wide visibility into resource utilization, application performance, and operational health. AWS CloudWatch is utilized to collect and track metrics, collect and monitor log files, set alarms, and automatically react to changes in AWS resources.

Servers and workstations utilize anti-virus endpoint protection, which is kept properly updated and conducts routine scans. Windows Server operating system patches for critical production systems are updated manually to ensure adequate testing and that no production interference will result. Workstation operating system patches are updated automatically to ensure critical vulnerabilities are patched as soon as possible. A central service automatically pushes updates on a periodic basis for routine patching, and immediately for critical vulnerabilities.

Software

Software consists of the programs and software that support the applications within the scope of the description. The list of software and ancillary software used to build, support, secure, maintain, and monitor the educational tools and support services includes the following applications, as shown in the table below:

Component	Description
Hosting Systems	AWS Elastic Cloud Compute (EC2) AWS CloudFront Content Delivery Network Google Workspaces
Storage, Database, and Backups	AWS Simplified Storage Service (S3) Google Drive Microsoft SQL Server AWS Snapshots
Network and Firewall	AWS Load Balancers AWS Security Groups AWS GuardDuty AWS Network Firewall AWS CloudFront Content Delivery Network Cloudflare Security Services (WAF and DDoS) Bitdefender Endpoint Protection Microsoft Defender Endpoint Protection
Build, Release, Continuous Integration Systems, and Change Management	GitHub Version Control Jira Change Management Jenkins Continuous Integration
Access Management	Microsoft Active Directory AWS Identity and Access Management with Multifactor Authentication. OpenVPN Authentication Google Workspace Identity and Access Management

Component	Description
Monitoring, Alerting, Analytics, and Ticketing	Opsgenie Incident Management AWS CloudWatch Monitoring, Alerting, and Analytics Uptime Robot Monitoring and Alerting Salesforce Service Cloud Jira Ticketing
Vulnerability Scanning	AWS Inspector Security Assessment Service HostedScan Vulnerability Scanning and Risk Management AON External Penetration and Vulnerability Testing
Human Resource	Paycor Human Capital Management Sterling Talent Solutions Background Screening SANS Institute Security Training

People

PROGRESS LEARNING is led by its CEO, Will Clemens, and executives in the departmental areas of Technology, Product Development, Finance, Human Resources, and Sales and Marketing. PROGRESS LEARNING's organization structure provides the overall framework for planning, directing, and controlling operations. Personnel and business functions are separated into departments according to job responsibilities. The structure provides defined responsibilities and lines of authority for reporting and communication. The assignment of roles and responsibilities within the various departments provides effective segregation of duties.

In the Control Environment section of this report, additional information is described related to organizational controls implemented at PROGRESS LEARNING. These organizational controls are intended to serve as the internal foundation for providing services to its customers.

Procedures

PROGRESS LEARNING has implemented processes and procedures to support the operations and controls over the services and systems provided to its customers. Specific examples of the relevant procedures include, but are not limited to, the following:

- Policies and procedures are in place to guide personnel regarding assessing risks on a periodic basis.
- Security policies are in place to guide personnel regarding physical and information security practices.
- Policies and procedures are in place for identifying the system security requirements of authorized users.
- Third-party enterprise monitoring applications are used to monitor system downtime and operations issues to help ensure that system downtime and performance does not exceed predefined levels.

- An Incident Response plan is in place to ensure appropriate response to outages or security incidents in an organized and timely manner.
- Policies and procedures are in place to guide personnel regarding addressing how complaints and requests relating to security issues are resolved.
- Policies and procedures are in place to assign responsibility and accountability for system changes and maintenance.
- Policies and procedures are in place to guide personnel regarding identifying and mitigating security breaches and other incidents.
- PROGRESS LEARNING IT personnel utilize security issue monitoring services to keep abreast of recent critical issues, attacks and vulnerabilities that must be addressed immediately.
- Firewall systems are in place to handle data flow between external parties and cloud hosted networks. External traffic originating from the Internet must pass through a firewall system to communicate with production servers. No direct conversations originating from the Internet pass directly through to the cloud private networks.
- Policies and procedures are in place to add new users, modify the access levels of existing users, and remove users who no longer need access.
- Production server users are required to authenticate via a unique user ID and password before being granted access to the production environment. Multifactor authentication is enabled.
- Application users are required to authenticate via an authorized unique account ID, user ID and password before being granted access to the production environment.
- Each customer is assigned a designated administrator during the onboarding process with authority to create or modify user access to the hosted user application for their organization.
- Antivirus software is installed on all PROGRESS LEARNING servers (endpoint protection).
- Management periodically performs internal security assessments, including reviews of server logs and other critical items.
- Policies and procedures are in place to ensure that design, acquisition, implementation, configuration, modification, and management of infrastructure and software are consistent with defined system security policies to enable authorized access and to prevent unauthorized access.
- Policies and procedures are in place to ensure that change management processes are initiated when deficiencies in the design or operating effectiveness of controls are identified during system operation and monitoring.

Data

Data refers to transaction streams, files, data stores, tables, and output used or processed by PROGRESS LEARNING and typically includes the following defined categories:

- PUBLIC – pertains to all data that does not require specific accountability and/or audit trails for use. The unauthorized disclosure of this data would not cause any adverse impact to PROGRESS LEARNING's reputation, financials, or client engagements. Such information includes non-strategic information, publicly available information, or non-specific application information.
- INTERNAL – pertains to all information created by an individual user of the internal system and not meant to be generally shared with others. The unauthorized disclosure of this information reasonably could be expected to cause low substantive damage to PROGRESS LEARNING's reputation, financials, or client relations. Such information and communication of it is intended by the creator for a specific audience only.

- **INTERNAL SENSITIVE** – pertains to all data having compromising or competitive elements or implications intended strictly for use within PROGRESS LEARNING. Such information includes but is not limited to basic financial, security, and audit information.
- **CONFIDENTIAL** – pertains to all data of the highest sensitivity due to its time and financial sensitivity or possible fraud potential. Such data includes all types of identifiable information, social security numbers, health records, account numbers, payroll, personal information, passwords, code, client relations/engagements, and contracts under negotiation.

Access to data is limited to authorized personnel in accordance with PROGRESS LEARNING's system security policies. PROGRESS LEARNING is also responsible for the overall availability of data, including system backups, monitoring of data processing, and file transmissions as well as identifying and resolving problems.

Encryption is utilized to protect data in transit, including TLS encryption over HTTPS connections utilized for secure communications between PROGRESS LEARNING and customer end users. Certain IT engineers access production network equipment and data stored at the third party data center remotely, via secure VPN tunnels protected by TLS encryption. For protection of static data on servers, the data is stored encrypted with AES 256-bit encryption.

Controls in place specific to the data responsibilities of PROGRESS LEARNING include, but are not limited to, the following:

- Employees must sign a confidentiality and non-disclosure agreement to not disclose proprietary or confidential information, including client information, to unauthorized parties.
- Firewall systems are in place to handle data flow between external parties and cloud hosted networks. External traffic originating from the Internet must pass through a firewall system to communicate with production servers. No direct conversations originating from the Internet pass directly through to the cloud private networks.
- A secure VPN (Virtual Private Network) connection is used for remote external access to the production network by authorized PROGRESS LEARNING employees.
- Policies and procedures are in place to guide personnel regarding sharing information with third parties.
- Communication sessions between PROGRESS LEARNING's servers/applications and external parties are secured using various encryption methods when applicable.
- File transfer sessions that utilize production server applications are secured through the use of encryption.
- Transaction processing performed on web-based applications is secured through the use of the Transport Layer Security (TLS) encryption protocol over HTTPS connections.
 - This includes the use of the website file upload page.
 - Traffic directed to HTTP connections for this are redirected to HTTPS connections.

Disaster Recovery

PROGRESS LEARNING maintains a current Disaster Recovery Plan and Business Continuity plan. Disaster and business continuity emergency situations are ultimately managed through proper planning (crisis management, recovery and continuity) and response. Identified risks have been mitigated through prevention, minimization or rapid recovery resources and planning. PROGRESS LEARNING's disaster recovery and business continuity program helps to ensure that disruptive incidents are responded to quickly and effectively.

CONTROL ENVIRONMENT

Integrity and Ethical Values

The effectiveness of controls cannot rise above the integrity and ethical values of the people who create, administer, and monitor them. Integrity and ethical values are essential elements of PROGRESS LEARNING's control environment, affecting the design, administration, and monitoring of other components. Integrity and ethical behavior are the products of PROGRESS LEARNING's ethical and behavioral standards, how they are communicated, and how they are reinforced in daily practice.

These standards include management's actions to remove or reduce incentives and temptations that might prompt personnel to engage in dishonest, illegal, or unethical acts. They also include the communication of entity values and behavioral standards to personnel through policy statements and codes of conduct, and by personal example.

Specific control activities that PROGRESS LEARNING has implemented in this area are described below.

- PROGRESS LEARNING maintains an employee handbook which contains organizational policy statements, behavioral standards, codes of conduct and disciplinary policies to which all employees are required to adhere.
- Policies and procedures require that new employees sign an employee handbook acknowledgment form indicating that they have been given access to it and understand their responsibilities. The signed form is kept in the employee personnel file.
- Employees must sign a confidentiality and non-disclosure agreement to not disclose proprietary or confidential information, including client information, to unauthorized parties.
- Comprehensive background checks are performed by an independent third party for certain positions as a component of the hiring process.
- *Contract employees (1099)* must sign a confidentiality and non-disclosure agreement to not disclose proprietary or confidential information, including client information, to unauthorized parties.
- Comprehensive background checks are performed by an independent third party for *certain contract employees (1099)* as a component of the hiring process.
- Management maintains a commercial general liability insurance policy with Technology Errors and Omissions Liability & Cyber coverage.

Commitment to Competence

PROGRESS LEARNING's management defines competence as the knowledge and skills necessary to accomplish tasks that define employees' roles and responsibilities. PROGRESS LEARNING's commitment to competence includes management's consideration of the competence levels for particular jobs and how those levels translate into requisite skills and knowledge.

Specific control activities that PROGRESS LEARNING has implemented in this area are described below.

- Management has considered the competence levels for particular jobs and translated required skills and knowledge levels into written job descriptions.
- Candidates' abilities to meet job requirements are evaluated as part of the hiring, performance review, and transfer evaluation processes.
- Roles and responsibilities for company personnel to interact with and monitor the activities of external third-party information technology vendors are defined in written job descriptions and communicated to personnel.
- Management has developed a training and development program for employees. This includes initial training/orientation with peers and supervisors in the period immediately after hire.
- Management encourages employees to complete and continue formal education and technical certification programs. (formally or informally)
- Certain approved professional development expenses incurred by the employees are paid by PROGRESS LEARNING. (training certs, classes, etc.)
- Each employee undergoes an annual performance review. A formal evaluation is prepared and maintained in the employee's HR file.
- PROGRESS LEARNING utilizes an independent CPA firm to audit its financial statements.

Board of Directors' Participation

PROGRESS LEARNING's control consciousness is influenced significantly by its Board of Directors participation. The Board of Directors oversees management activities and meets quarterly to discuss strategic, operational, and compliance issues. The board of directors contains members who are independent from management and are objective in evaluations and decision making.

Management's Philosophy and Operating Style

PROGRESS LEARNING's management philosophy and operating style encompasses a broad range of characteristics. Such characteristics include management's approach to taking and monitoring business risks and management's attitudes toward the educational tools and support services, information processing, accounting functions and personnel. Management is periodically briefed on regulatory and industry changes affecting services provided. Management meetings are held on a periodic basis to discuss and monitor operational issues.

Specific control activities that PROGRESS LEARNING has implemented in this area are described below.

- Management communicates the importance of Information Security through ongoing Information Security related training for employees, documenting and implementing Information Security policies, and having frequent discussions with employees regarding the critical nature of Information Security including individual responsibilities for data and systems security.

- Management stays current on regulatory compliance or operational trends affecting the services provided by attending trade shows, utilizing trade and regulatory publications, journals, online news feeds or government sites, or belonging to industry associations.
- Operational meetings are held on a regular basis to discuss internal control responsibilities (*data and system security*) of individuals and performance measurement.
- PROGRESS LEARNING utilizes an independent CPA firm to audit its financial statements.

Organization Structure and Assignment of Authority and Responsibility

PROGRESS LEARNING's organization structure provides the framework within which its activities for achieving entity-wide objectives are planned, executed, controlled, and monitored. PROGRESS LEARNING's management believes that establishing a relevant organization structure includes considering key areas of authority and responsibility and appropriate lines of reporting. PROGRESS LEARNING has developed an organization structure suited to its needs. This organization structure is based, in part, on its size and the nature of its activities.

PROGRESS LEARNING's assignment of authority and responsibility activities include factors such as how authority and responsibility for operating activities are assigned and how reporting relationships and authorization hierarchies are established. It also includes policies relating to appropriate business practices, knowledge and experience of key personnel, and resources provided for carrying out duties. In addition, it includes policies and communications directed at ensuring that all personnel understand the entity's objectives, know how their individual actions interrelate and contribute to those objectives, and recognize how and for what they will be held accountable.

Specific control activities that PROGRESS LEARNING has implemented in this area are described below.

- Organizational charts are in place to communicate key areas of authority, responsibility, and appropriate lines of reporting to personnel.

Human Resource Policies and Practices

PROGRESS LEARNING's human resources policies and practices relate to employee hiring, orientation, training, evaluation, counseling, promotion, compensation, and disciplinary activities.

Specific control activities that PROGRESS LEARNING has implemented in this area are described below.

- Management utilizes a new hire checklist to ensure that specific elements of the hiring process are consistently executed. A copy of the checklist is kept in the employee file.
- Comprehensive background checks are performed by an independent third party for certain positions as a component of the hiring process.
- Comprehensive background checks are performed by an independent third party for *certain contract employees (1099)* as a component of the hiring process.
- PROGRESS LEARNING maintains an employee handbook which contains organizational policy statements, behavioral standards, codes of conduct and disciplinary policies to which all employees are required to adhere.

- Management has developed a training and development program for employees. This includes initial training/orientation with peers and supervisors in the period immediately after hire.
- Each employee undergoes an annual performance review. A formal evaluation is prepared and maintained in the employee's HR file.
- Management utilizes a termination checklist to ensure that specific elements of the termination process are consistently executed. A copy of the checklist is kept in the employee file.

RISK ASSESSMENT

Management is responsible for identifying the risks that threaten achievement of the control objectives stated in the management's description of the services and systems. Management has implemented a process for identifying relevant risks. This process includes estimating the significance of identified risks, assessing the likelihood of their occurrence, and deciding about actions to address them. However, because control objectives relate to risk that controls seek to mitigate, management thoughtfully identified control objectives when designing, implementing, and documenting their system.

Objective Setting

PROGRESS LEARNING establishes objectives in order for management to identify potential events affecting their achievement. PROGRESS LEARNING has placed into operation a risk management process to help ensure that the chosen control objectives support and align with the organization's mission and are consistent with its risk framework. Objective setting enables management to identify measurement criteria for performance, with focus on success factors.

PROGRESS LEARNING has established certain broad categories including:

- **Strategic Objectives** — these pertain to the high level organizational goals and the alignment of those goals to support the overall mission
- **Operations Objectives** — these pertain to effectiveness and efficiency of the entity's operations, including performance and profitability goals and safeguarding of resources against loss
- **Reporting Objectives** — these pertain to the preparation of reliable reporting
- **Compliance Objectives** — these pertain to adherence to laws and regulations to which the entity is subject

Risks Identification

Regardless of whether an objective is stated or implied, an entity's risk-assessment process should consider risks that may occur. It is important that risk identification be comprehensive. PROGRESS LEARNING has considered significant interactions between itself and relevant external parties and risks that could affect the organization's ability to provide reliable service to its user entities.

Management considers risks that can arise from both external and internal factors including:

External Factors

- Technological developments
- Changing customer needs or expectations
- Competition that could alter marketing or service activities
- New legislation and regulation that could force changes in policies and strategies
- Natural catastrophes that could lead to changes in operations or information systems
- Economic changes that could have an impact on management decisions

Internal Factors

- Significant changes in policies, processes, or personnel
- Types of fraud
- Fraud incentives, pressures, and opportunities for employees, as well as employee attitudes and rationalizations for fraud
- A disruption in information systems processing
- The quality of personnel hired, and methods of training utilized
- Changes in management responsibilities

The PROGRESS LEARNING risk assessment process focuses on supporting management decisions and responding to potential threats by assessing risks and identifying important decision factors. PROGRESS LEARNING senior management oversees risk management ownership, accountability, and is involved in risk identification process. Management identifies elements of business risk including threats, vulnerabilities, safeguards and the likelihood of a threat, to determine the actions to be taken.

Risks Analysis

PROGRESS LEARNING's methodology for analyzing risks varies, largely because many risks are difficult to quantify. Nonetheless, the process includes:

- Estimating the significance of a risk
- Assessing the likelihood (or frequency) of the risk occurring
- Considering how the risk should be managed, including an assessment of what actions need to be taken

Risk analysis is an essential process to the entity's success. It includes identification of key business processes where potential exposures of some consequence exist. Once the significance and likelihood of risk have been assessed, management considers how the risk should be managed. This involves judgment based on assumptions about the risk, and reasonable analysis of costs associated with reducing the level of risk. Necessary actions are taken to reduce the significance or likelihood of the risk occurring.

CONTROL OBJECTIVES AND RELATED CONTROL ACTIVITIES

Integration with Risk Assessment

Along with assessing risks, management has identified and put into effect actions needed to address those risks. In order to address risks, control activities have been placed into operation to help ensure that the actions are carried out properly and efficiently. Control activities serve as mechanisms for managing the achievement of those objectives.

Selection and Development of Control Activities

Control activities are a part of the process by which PROGRESS LEARNING strives to achieve its business objectives. PROGRESS LEARNING has applied a risk management approach to the organization in order to select and develop control activities. After relevant risks have been identified and evaluated, controls are established, implemented, monitored, reviewed and improved when necessary to meet the overall objectives of the organization.

The applicable trust criteria and related control activities are included in Section 4 (the "Testing Matrices") of this report to eliminate the redundancy that would result from listing the items in this section and repeating them in the Testing Matrices. Although the applicable trust criteria and related control activities are included in the Testing Matrices, they are, nevertheless, an integral part of PROGRESS LEARNING's description of controls and systems.

The description of the service auditor's tests of operating effectiveness and the results of those tests are also presented in the Testing Matrices, adjacent to the service organization's description of controls. The description of the tests of operating effectiveness and the results of those tests are the responsibility of the service auditor and should be considered information provided by the service auditor.

MONITORING

PROGRESS LEARNING's management performs monitoring activities in order to continuously assess the quality of internal control over time. Monitoring activities are used to initiate corrective action through department meetings, client conference calls, and informal notifications. Management performs monitoring activities on a continuous basis and necessary corrective actions are taken as required to correct deviations from company policy and procedures.

Ongoing and Separate Evaluations of the Control Environment

Monitoring can be done in two ways: through ongoing activities or separate evaluations. The greater the degree and effectiveness of ongoing monitoring, the less the need is for separate evaluations. Management determines the need for separate evaluations by consideration given to the following: the nature and degree of changes occurring and their associated risks, the competence and experience of the people implementing the controls, as well as the results of the ongoing monitoring. Management has implemented a combination of ongoing monitoring and separate evaluations, as deemed necessary; to help ensure that the internal control system maintains its effectiveness over time.

Ongoing Monitoring

Examples of PROGRESS LEARNING's ongoing monitoring activities include the following:

- In carrying out its regular management activities, operating management obtains evidence that the system of internal control continues to function.
- Communications from external parties and customers corroborate internally generated information or indicate problems.
- Organization structure and supervisory activities provide oversight of control functions and identification of deficiencies.
- Training, planning sessions, and other meetings provide important feedback to management on whether controls are effective.
- Personnel are briefed on organizational policy statements and codes of conduct to communicate entity values.

Separate Evaluations

Evaluation of an entire internal control system may be prompted by a number of reasons: major strategy or management change, major acquisitions or dispositions, or significant changes in operations or methods of processing information. Evaluations of internal control vary in scope and frequency, depending on the significance of risks being controlled and importance of the controls in reducing the risks. Controls addressing higher-priority risks and those most essential to reducing a given risk will tend to be evaluated more often.

Often, evaluations take the form of self-assessments, where persons responsible for a particular unit or function will determine the effectiveness of controls for their activities. These assessments are considered by management, along with any other internal control evaluations. The findings of these efforts are utilized to ensure follow-up actions are taken and subsequent evaluations are modified as necessary.

Monitoring of the Subservice Organizations

PROGRESS LEARNING uses the subservice organization, Amazon Web Services (AWS), to provide third-party data center/cloud hosting/colocation services. Management of PROGRESS LEARNING receives and reviews the SOC report of AWS annually. In addition, through its operational activities, PROGRESS LEARNING management monitors the services performed by the subservice organization to determine whether operations and controls expected to be implemented are functioning effectively. Management also has ongoing communication with the subservice organization to monitor compliance with the service agreement, stay informed of changes planned at the hosting facility, and relay any issues or concerns to subservice organization management.

Reporting Deficiencies

Deficiencies in management's internal control system surface from many sources, including PROGRESS LEARNING's ongoing monitoring procedures, separate evaluations of the internal control system and external parties. Management has developed protocols to help ensure findings of internal control deficiencies are reported not only to the individual responsible for the function or activity involved, who is in the position to take corrective action, but also to at least one level of management above the directly responsible person. This process enables that individual to provide needed support or oversight for taking corrective action, and to communicate with others in the organization whose activities may be affected. Management evaluates the specific facts and circumstances related to deficiencies in internal control procedures and makes the decision for addressing deficiencies based on whether the incident was isolated or requires a change in PROGRESS LEARNING's procedures or personnel.

INFORMATION AND COMMUNICATION SYSTEMS

Information Systems

A combination of custom developed and commercial applications is utilized to support the educational tools and support services provided to user entities. The applications run on Windows Server operating systems in AWS' highly secure and scalable cloud environment with commercial databases to support the applications.

Redundancy is maintained for components of the data infrastructure. Systems are developed and deployed to enable the addition of bandwidth and server capacity quickly to support customer requirements. External services and internal applications constantly monitor communications, job logs, system performance, and security and send alerts to the operations staff before customers are affected.

Communication Systems

Internal Communications

Upper management is involved with day-to-day operations and is able to provide personnel with an understanding of their individual roles and responsibilities pertaining to internal controls. This includes the extent to which personnel understand how their activities relate to the work of others and the means of reporting exceptions to a higher level within PROGRESS LEARNING. Management believes that open communication channels help ensure that exceptions are reported and acted on. For that reason, formal communication tools such as organizational charts, employee handbooks, training classes and job descriptions are in place at PROGRESS LEARNING. Management's communication activities are made electronically, verbally, and through the actions of management.

External Communications

PROGRESS LEARNING utilizes various methods of communication to help ensure that customers and other external parties understand their roles and responsibilities in processing transactions and the communication of significant events. These methods include periodic meetings with customers and other external parties, the use of email through daily operations, and the customer telephone support lines to communicate critical and time-sensitive information.

COMPLEMENTARY USER ENTITY CONTROLS (CUECs)

PROGRESS LEARNING's services are designed with the assumption that certain controls will be implemented by user entities. Such controls are called complementary user entity controls. It is not feasible for all of the control objectives related to PROGRESS LEARNING's educational tools and support services to be solely achieved by PROGRESS LEARNING's control procedures. Accordingly, user entities, in conjunction with the services, should establish their own internal controls or procedures to complement those of PROGRESS LEARNING.

The following complementary user entity controls should be implemented by user entities to provide additional assurance that the service commitments and system requirements described within this report are met. As these items represent only a part of the control considerations that might be pertinent at the user entities' locations, user entities' auditors should exercise judgment in selecting and reviewing these complementary user entity controls, which may include:

- User entities are responsible for understanding and complying with their contractual obligations to PROGRESS LEARNING. (CC2.3; CC5.3; CC9.2)
- User entities are responsible for developing their own disaster recovery and business continuity plans that address their ability to access or utilize PROGRESS LEARNING services. (CC5.2; CC7.2; A1.2; A1.3)
- User entities are responsible for ensuring that user IDs and passwords used to access PROGRESS LEARNING applications are kept in a secure manner and only used by authorized employees. (CC6.1; CC6.2; CC6.3; CC6.4)
- User entities are responsible for requesting an authorized user ID and password for user entity employees. User entities are responsible for defining the level of access given to employees and customers. (CC6.1; CC6.2; CC6.3; CC6.4)
- User entities are responsible for requesting the revocation of application access privileges assigned to terminated employees as a component of the employee termination process. (CC6.1; CC6.2; CC6.3; CC6.4)
- User entities are responsible for restricting administrative privileges within the application or systems to authorized personnel and for designating internal personnel who are authorized to request user additions, deletions, and security level changes. (CC6.1; CC6.2; CC6.3; CC6.4)
- User entities are responsible for notifying PROGRESS LEARNING of changes made to technical or administrative contact information in a timely manner. (CC6.2)
- User entities are responsible for understanding and defining data storage requirements. (CC4.1)
- User entities are responsible for understanding and implementing encryption protocols to protect data during transfer to PROGRESS LEARNING. (CC6.6; CC6.7)
- User entities are responsible for immediately notifying PROGRESS LEARNING of any actual or suspected information security breaches, including compromised user accounts and passwords. (CC7.2)
- User entities are responsible for notifying PROGRESS LEARNING of any regulatory issues that may affect the services provided by PROGRESS LEARNING. (CC2.3; CC3.2)
- User entities are responsible for maintaining their own system(s) of record. (CC6.1)
- User entities are responsible for defining the authentication method for the software. User entities may store the username and password in the client or require them to be entered each time a user accesses the software. (CC6.1)

COMPLEMENTARY SUBSERVICE ORGANIZATION CONTROLS (CSOCs)

PROGRESS LEARNING uses a subservice organization, Amazon Web Services (AWS), to provide third-party data center/cloud hosting/colocation services to house its critical production computer servers, applications, and networking equipment.

In designing its system, PROGRESS LEARNING has contemplated that certain complementary controls would be implemented by the subservice organization to achieve the applicable criteria included in this report. This section describes the subservice organization's internal controls that, in combination with the controls at PROGRESS LEARNING, provide reasonable assurance that PROGRESS LEARNING's service commitments and system requirements can be achieved.

The complementary subservice organization controls expected to be implemented at the subservice organization are described below:

- Subservice Organizations are responsible for ensuring that data center access for their employees, contractors, vendors, and clients is added only for authorized individuals. (CC6.3; CC6.4)
- Subservice Organizations are responsible for ensuring that data center access for their employees, contractors, vendors, and clients is removed when no longer required. (CC6.5)
- Subservice Organizations are responsible for implementing physical access mechanisms to ensure only authorized badge holders can enter the data centers. (CC6.3; CC6.4)
- Subservice Organizations are responsible for ensuring customer-specific areas with the data center can only be accessed by the customer. (CC6.3; CC6.4)
- Subservice Organizations are responsible for providing environmental security and maintenance controls that are designed, developed, implemented, operated, maintained, and monitored to meet availability commitments and requirements. (A1.2)
- Subservice Organizations are responsible for the general IT controls relevant to its application development and/or change management. (CC8.1)
- Subservice Organizations are responsible for the controls relevant to the completeness and accuracy of specified reports provided to and used by PROGRESS LEARNING. (CC4.1; A1.2)

SPECIFIC CRITERIA NOT RELEVANT TO THE SYSTEM

There were no specific Trust Services Criteria as set forth in TSP section 100 that were not relevant to the system as presented in this report.

SIGNIFICANT CHANGES TO THE SYSTEM

There were no significant changes that are likely to affect report users' understanding of how the educational tools and support services and systems are used to provide the service from October 1, 2024 to September 30, 2025.

SIGNIFICANT INCIDENTS DURING THE PERIOD

There were no identified system incidents during the period from October 1, 2024 to September 30, 2025 that (a) were the result of controls that were not suitably designed or operating effectively or (b) otherwise resulted in a significant failure in the achievement of one or more of the service commitments and system requirements.

SECTION 4

TESTING MATRICES

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC1.0 - COMMON CRITERIA RELATED TO THE CONTROL ENVIRONMENT

The criteria relevant to how the entity (i) demonstrates commitment to integrity and ethical values, (ii) exercises oversight responsibility, (iii) establishes structure, authority and responsibility, (iv) demonstrates commitment to competence, and (v) enforces accountability.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC1.1	COSO Principle 1: The entity demonstrates a commitment to integrity and ethical values.	PROGRESS LEARNING maintains an employee handbook which contains organizational policy statements, behavioral standards, codes of conduct and disciplinary policies to which all employees are required to adhere.	Inspected the employee handbook to determine that it contains organizational policy statements, behavioral standards, codes of conduct and disciplinary policies to which all employees are required to adhere.	No exceptions noted.
		Policies and procedures require that new employees sign an employee handbook acknowledgment form indicating that they have been given access to it and understand their responsibilities. The signed form is kept in the employee personnel file.	Inspected completed acknowledgment forms for a sample of employees hired during the review period to determine that policies and procedures require that new employees sign an acknowledgment form indicating that they have been given access to the employee handbook and understand their responsibilities.	No exceptions noted.
		Employees must sign a confidentiality and non-disclosure agreement to not disclose proprietary or confidential information, including client information, to unauthorized parties.	Inspected completed acknowledgment forms for a sample of employees hired during the review period to determine that the employees signed a confidentiality agreement to not disclose proprietary or confidential information, including client information, to unauthorized parties.	No exceptions noted.
		Comprehensive background checks are performed by an independent third party for <i>certain</i> positions as a component of the hiring process.	Inspected background check documentation for a sample of employees hired during the review period to determine that background checks are performed by an independent third party.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC1.0 - COMMON CRITERIA RELATED TO THE CONTROL ENVIRONMENT

The criteria relevant to how the entity (i) demonstrates commitment to integrity and ethical values, (ii) exercises oversight responsibility, (iii) establishes structure, authority and responsibility, (iv) demonstrates commitment to competence, and (v) enforces accountability.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		<i>Contract employees (1099)</i> must sign a confidentiality and non-disclosure agreement to not disclose proprietary or confidential information, including client information, to unauthorized parties.	Inspected completed acknowledgment forms for a sample of <i>contract employees</i> hired during the review period to determine that the <i>contract employees (1099)</i> signed a confidentiality agreement to not disclose proprietary or confidential information, including client information, to unauthorized parties.	No exceptions noted.
		Comprehensive background checks are performed by an independent third party for <i>certain contract employees (1099)</i> as a component of the hiring process.	Inspected background check documentation for a sample of <i>contract employees</i> hired during the review period to determine that background checks are performed by an independent third party.	No exceptions noted.
		Management maintains a commercial general liability insurance policy with Technology Errors and Omissions Liability & Cyber coverage	Inspected insurance coverage policy declarations page to determine that management maintained a commercial general liability insurance policy with Technology Errors and Omissions Liability & Cyber coverage.	No exceptions noted.
		PROGRESS LEARNING utilizes an independent CPA firm to audit its financial statements.	Inquired of management to determine that PROGRESS LEARNING utilizes an independent CPA firm to audit its financial statements.	No exceptions noted.
			Inspected the most recent engagement letter reflecting the engagement of an independent CPA firm to determine that PROGRESS LEARNING utilizes an	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY
CC1.0 - COMMON CRITERIA RELATED TO THE CONTROL ENVIRONMENT

The criteria relevant to how the entity (i) demonstrates commitment to integrity and ethical values, (ii) exercises oversight responsibility, (iii) establishes structure, authority and responsibility, (iv) demonstrates commitment to competence, and (v) enforces accountability.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC1.2	COSO Principle 2: The board of directors demonstrates independence from management and exercises oversight of the development and performance of internal control.	A board of directors oversees management activities.	independent CPA firm to audit its financial statements. Inquired of management regarding the board of directors to determine that a board of directors was in place to oversee management activities.	No exceptions noted.
			Inspected the listing of the board of director members to determine that a board of directors was in place.	No exceptions noted.
		The board of directors contains members who are independent from management and are objective in evaluations and decision making.	Inspected the board of directors member listing and inquired of management to determine that the board of directors contained members who were independent from management and were objective in evaluations and decision making.	No exceptions noted.
		The board of directors meets on a quarterly basis.	Inspected a sample of BOD meeting agendas to determine that a board of directors meets quarterly.	No exceptions noted.
CC1.3	COSO Principle 3: Management establishes, with board oversight, structures, reporting lines, and appropriate authorities and responsibilities in the pursuit of objectives.	Management has considered the competence levels for particular jobs and translated required skills and knowledge levels into written job descriptions.	Inspected a sample of written job descriptions to determine that management had considered the competence levels for particular jobs and translated required skills and knowledge levels into written job descriptions.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC1.0 - COMMON CRITERIA RELATED TO THE CONTROL ENVIRONMENT

The criteria relevant to how the entity (i) demonstrates commitment to integrity and ethical values, (ii) exercises oversight responsibility, (iii) establishes structure, authority and responsibility, (iv) demonstrates commitment to competence, and (v) enforces accountability.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC1.4	COSO Principle 4: The entity demonstrates a commitment to attract, develop, and retain competent individuals in alignment with objectives.	Roles and responsibilities for company personnel to interact with and monitor the activities of external third-party information technology vendors are defined in written job descriptions and communicated to personnel.	Inspected a sample of written job descriptions to determine that written job descriptions contain roles and responsibilities for company personnel to interact with and monitor the activities of external third-party information technology vendors.	No exceptions noted.
		Organizational charts are in place to communicate key areas of authority, responsibility, and appropriate lines of reporting to personnel.	Inspected organizational charts to determine that organizational charts are in place to communicate key areas of authority, responsibility, and appropriate lines of reporting to personnel.	No exceptions noted.
		Management has authorized specific personnel to administer information security within the production environment.	Inspected the access rights listing to determine that management has authorized specific personnel to administer information security within the production environment.	No exceptions noted.
		Policies and procedures are in place to guide personnel regarding providing for training and other resources to support its system security policies.	Inspected the policies and procedures to determine that the entity's policies included procedures regarding training and other resources to support its system security policies.	No exceptions noted.
		Comprehensive background checks are performed by an independent third party for <i>certain</i> positions as a component of the hiring process.	Inspected background check documentation for a sample of employees hired during the review period to determine that background checks are performed by an independent third party.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC1.0 - COMMON CRITERIA RELATED TO THE CONTROL ENVIRONMENT

The criteria relevant to how the entity (i) demonstrates commitment to integrity and ethical values, (ii) exercises oversight responsibility, (iii) establishes structure, authority and responsibility, (iv) demonstrates commitment to competence, and (v) enforces accountability.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Management has considered the competence levels for particular jobs and translated required skills and knowledge levels into written job descriptions.	Inspected a sample of written job descriptions to determine that management had considered the competence levels for particular jobs and translated required skills and knowledge levels into written job descriptions.	No exceptions noted.
		Candidates' abilities to meet job requirements are evaluated as part of the hiring, performance review, and transfer evaluation processes.	Inquired of management to determine that candidates' abilities to meet job requirements are evaluated as part of the hiring, performance review, and transfer evaluation processes.	No exceptions noted.
		Management has developed a training and development program for employees. This includes initial training/orientation with peers and supervisors in the period immediately after hire.	Inquired of management into initial training and development for employees to determine that a program is in place which includes initial training/orientation with peers and supervisors in the period immediately after hire.	No exceptions noted.
		Management encourages employees to complete and continue formal education and technical certification programs. (formally or informally)	Inquired of management into encouragement of employees to pursue formal education and technical certification programs to determine that management encourages employees to complete and continue formal education and technical certification programs.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC1.0 - COMMON CRITERIA RELATED TO THE CONTROL ENVIRONMENT

The criteria relevant to how the entity (i) demonstrates commitment to integrity and ethical values, (ii) exercises oversight responsibility, (iii) establishes structure, authority and responsibility, (iv) demonstrates commitment to competence, and (v) enforces accountability.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC1.5	COSO Principle 5: The entity holds individuals accountable for their internal control responsibilities in the pursuit of objectives.	Certain approved professional development expenses incurred by the employees are paid by PROGRESS LEARNING. (training certs, classes, etc.)	Inquired of management to determine that certain approved professional development expenses incurred by the employees are paid by PROGRESS LEARNING.	No exceptions noted.
		Management communicates the importance of Information Security through ongoing Information Security related training for employees, documenting and implementing Information Security policies, and having frequent discussions with employees regarding the critical nature of Information Security including individual responsibilities for data and systems security.	Inquired of management and inspected relevant documentation to determine that management communicates the importance of Information Security through ongoing Information Security related training for employees, documenting and implementing Information Security policies, and having frequent discussions with employees regarding the critical nature of Information Security including individual responsibilities for data and systems security.	No exceptions noted.
		Management has authorized specific personnel to administer information security within the production environment.	Inspected the access rights listing to determine that management has authorized specific personnel to administer information security within the production environment.	No exceptions noted.
		A policy is in place to assign responsibility and accountability for developing and maintaining the entity's security policies, and changes and updates to those policies, to appropriate personnel.	Inspected the policies and procedures to determine that responsibility and accountability for developing and maintaining the entity's system security policies, and changes and updates to those policies, were assigned to appropriate personnel.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC1.0 - COMMON CRITERIA RELATED TO THE CONTROL ENVIRONMENT

The criteria relevant to how the entity (i) demonstrates commitment to integrity and ethical values, (ii) exercises oversight responsibility, (iii) establishes structure, authority and responsibility, (iv) demonstrates commitment to competence, and (v) enforces accountability.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Operational meetings are held on a regular basis to discuss internal control responsibilities (<i>data and system security</i>) of individuals and performance measurement.	Inquired of management to determine that operational meetings are held on a regular basis to discuss internal control responsibilities (<i>data and system security</i>) of individuals and performance measurement.	No exceptions noted.
		Management communicates the importance of Information Security through ongoing Information Security related training for employees, documenting and implementing Information Security policies, and having frequent discussions with employees regarding the critical nature of Information Security including individual responsibilities for data and systems security.	Inquired of management and inspected relevant documentation to determine that management communicates the importance of Information Security through ongoing Information Security related training for employees, documenting and implementing Information Security policies, and having frequent discussions with employees regarding the critical nature of Information Security including individual responsibilities for data and systems security.	No exceptions noted.
		Each employee undergoes an annual performance review. A formal evaluation is prepared and maintained in the employee's HR file.	Inspected annual performance review documentation to determine that each employee undergoes an annual performance review.	No exceptions noted.
			Inquired of management to determine that a formal evaluation is prepared and maintained in the employee's HR file.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC1.0 - COMMON CRITERIA RELATED TO THE CONTROL ENVIRONMENT

The criteria relevant to how the entity (i) demonstrates commitment to integrity and ethical values, (ii) exercises oversight responsibility, (iii) establishes structure, authority and responsibility, (iv) demonstrates commitment to competence, and (v) enforces accountability.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Organizational charts are in place to communicate key areas of authority, responsibility, and appropriate lines of reporting to personnel.	Inspected organizational charts to determine that organizational charts are in place to communicate key areas of authority, responsibility, and appropriate lines of reporting to personnel.	No exceptions noted.
		Management has authorized specific personnel to administer information security within the production environment.	Inspected the access rights listing to determine that management has authorized specific personnel to administer information security within the production environment.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC2.0 - COMMON CRITERIA RELATED TO COMMUNICATION AND INFORMATION

The criteria relevant to how the entity (i) uses relevant information, (ii) communicates internally, and (iii) communicates externally.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC2.1	COSO Principle 13: The entity obtains or generates and uses relevant, quality information to support the functioning of internal control.	A formal risk assessment is performed on an annual basis. Company objectives are determined, and risks and mitigation strategies are identified, evaluated, and formally documented in memo form. The risk assessment includes, but is not limited to, the following areas: • Data security (company data and client data). • Potential fraud and misconduct including how management and staff might engage in inappropriate actions from the use of IT and access to information. • Regulatory, economic, and physical environment in which the company operates. • Business environment, including industry, competitors, regulatory environment, and consumers. • Potential impact of new business lines, dramatically altered business lines, acquired or divested business operations on the system of internal control, rapid growth, changing reliance on foreign geographies, and new technologies. • Management and respective attitudes and philosophies on the system of internal control. • Vendor and business partner relationships including third-party data centers. • Systems and technology environment.	Inspected the annual risk assessment documentation to determine that a formal risk assessment was performed during the review period and that company objectives, identified risks, and mitigation strategies were formally documented.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC2.0 - COMMON CRITERIA RELATED TO COMMUNICATION AND INFORMATION

The criteria relevant to how the entity (i) uses relevant information, (ii) communicates internally, and (iii) communicates externally.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC2.2	COSO Principle 14: The entity internally communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control.	PROGRESS LEARNING has logical and physical security, change management, incident monitoring, and data classification, integrity, and retention controls, as necessary, with checks and balances woven into each applicable process to ensure quality of processing.	Inspected internal processes and procedures to determine that PROGRESS LEARNING has logical and physical security, change management, incident monitoring, and data classification, integrity, and retention controls, as necessary, with checks and balances woven into each applicable process to ensure quality of processing.	No exceptions noted.
		Policies and procedures are in place to guide personnel regarding providing for training and other resources to support its system security policies.	Inspected the policies and procedures to determine that the entity's policies included procedures regarding training and other resources to support its system security policies.	No exceptions noted.
		Policies and procedures are in place to guide personnel regarding the handling of exceptions and situations not specifically addressed in its system security policies.	Inspected the policies and procedures to determine that the entity's policies included procedures regarding the handling of exceptions and situations not specifically addressed in its system security policies.	No exceptions noted.
		Policies and procedures are in place to assign responsibility and accountability for system security.	Inspected the policies and procedures to determine that policies and procedures were in place to assign responsibility and accountability for system security.	No exceptions noted.
		Policies and procedures are in place for identifying the system security requirements of authorized users.	Inspected the policies and procedures to determine that the entity's system security policies were established.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC2.0 - COMMON CRITERIA RELATED TO COMMUNICATION AND INFORMATION

The criteria relevant to how the entity (i) uses relevant information, (ii) communicates internally, and (iii) communicates externally.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Security policies are in place to guide personnel regarding physical and information security practices.	Inspected the policies and procedures manual to determine that security policies were in place to guide personnel regarding physical and information security practices.	No exceptions noted.
		Policies and procedures are in place to guide personnel regarding addressing how complaints and requests relating to security issues are resolved.	Inspected the policies and procedures to determine that the entity's policies included procedures regarding resolution of complaints and requests relating to system security and related issues.	No exceptions noted.
		Policies and procedures are in place to communicate responsibility and accountability for the entity's confidentiality and related security policies and changes and updates to those policies.	Inspected the policies and procedures to determine that responsibility and accountability for the entity's confidentiality and related security policies and changes and updates to those policies were communicated to entity personnel responsible for implementing them.	No exceptions noted.
		Procedures have been implemented to protect confidential information in the event that a disclosed confidentiality practice is discontinued or changed to be less restrictive and to communicate these changes to external parties.	Inspected confidentiality policies and procedures to determine that procedures have been implemented to protect confidential information in the event that a disclosed confidentiality practice is discontinued or changed to be less restrictive and to communicate these changes to external parties.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC2.0 - COMMON CRITERIA RELATED TO COMMUNICATION AND INFORMATION

The criteria relevant to how the entity (i) uses relevant information, (ii) communicates internally, and (iii) communicates externally.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		An Incident Response plan is in place to ensure appropriate response to outages or security incidents in an organized and timely manner.	Inspected the incident response plan to determine that a plan is in place to ensure appropriate response to outages or security incidents.	No exceptions noted.
		PROGRESS LEARNING has established operational requirements that support the achievement of service commitments, relevant laws and regulations, and other system requirements. Service commitments to customers are documented and communicated in customer agreements provided to user entities.	Inspected a sample customer agreement to determine that service commitments to customers are documented and communicated in customer agreements provided to user entities.	No exceptions noted.
		Management has developed PROGRESS LEARNING's definition of system downtime and determined acceptance level criteria and how significant issues are communicated to external parties.	Inspected company documentation to determine that management has developed PROGRESS LEARNING's definition of system downtime and acceptance level criteria and how significant issues are communicated to external parties.	No exceptions noted.
		Third-party enterprise monitoring applications are used to monitor system downtime and operations issues to help ensure that system downtime and performance does not exceed predefined levels. This includes monitoring of both critical network and server hardware, as well as processes and services: • System uptime and downtime • Critical performance metrics (CPU utilization, storage, etc.). Problems with critical systems are remediated as necessary.	Inspected the enterprise monitoring applications to determine that third-party enterprise monitoring applications are used to monitor performance criteria for critical server and network equipment.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC2.0 - COMMON CRITERIA RELATED TO COMMUNICATION AND INFORMATION

The criteria relevant to how the entity (i) uses relevant information, (ii) communicates internally, and (iii) communicates externally.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
			Inspected the metrics tracking reports to determine that system downtime and operations issues were monitored.	No exceptions noted.
			Inspected a sample of Slack alerts to determine that problems with critical systems are remediated as necessary.	No exceptions noted.
		The enterprise monitoring application is configured to send alert notifications to operations personnel when predefined metrics are exceeded on monitored network devices. Alerts are communicated via SMS text or email to appropriate support personnel.	Inspected the enterprise monitoring application configuration screens to determine that performance thresholds are set, and alerts are communicated if pre-determined metrics are reached.	No exceptions noted.
		Management has documented information security policies and procedures to communicate corporate security standards to employees.	Inspected the information security policies to determine that management documented information security policies to communicate corporate security standards to employees.	No exceptions noted.
		Network diagrams are in place and communicated to appropriate personnel.	Inspected network diagrams to determine that network diagrams are in place and communicated to appropriate personnel.	No exceptions noted.
		PROGRESS LEARNING has implemented a backup policy, and backups of production systems and data are completed in a timely manner. The retention period for backup data has been defined by management.	Inquired of management to determine that PROGRESS LEARNING has implemented a backup policy, and that backups of production systems and data are completed in a timely manner.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC2.0 - COMMON CRITERIA RELATED TO COMMUNICATION AND INFORMATION

The criteria relevant to how the entity (i) uses relevant information, (ii) communicates internally, and (iii) communicates externally.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
			Inspected the backup policy, backup configurations, and a sample of backup logs to determine that PROGRESS LEARNING has implemented a backup policy, and that backups of production systems and data are completed in a timely manner.	No exceptions noted.
			Inspected the backup policy and backup configurations to determine that the retention period for backup data has been defined by management.	No exceptions noted.
		PROGRESS LEARNING maintains an employee handbook which contains organizational policy statements, behavioral standards, codes of conduct and disciplinary policies to which all employees are required to adhere.	Inspected the employee handbook to determine that it contains organizational policy statements, behavioral standards, codes of conduct and disciplinary policies to which all employees are required to adhere.	No exceptions noted.
		Policies and procedures require that new employees sign an employee handbook acknowledgment form indicating that they have been given access to it and understand their responsibilities. The signed form is kept in the employee personnel file.	Inspected completed acknowledgment forms for a sample of employees hired during the review period to determine that policies and procedures require that new employees sign an acknowledgment form indicating that they have been given access to the employee handbook and understand their responsibilities.	No exceptions noted.
		Employees must sign a confidentiality and non-disclosure agreement to not disclose proprietary	Inspected completed acknowledgment forms for a sample of employees hired during	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC2.0 - COMMON CRITERIA RELATED TO COMMUNICATION AND INFORMATION

The criteria relevant to how the entity (i) uses relevant information, (ii) communicates internally, and (iii) communicates externally.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		or confidential information, including client information, to unauthorized parties. Management communicates the importance of Information Security through ongoing Information Security related training for employees, documenting and implementing Information Security policies, and having frequent discussions with employees regarding the critical nature of Information Security including individual responsibilities for data and systems security. The chief technology officer is responsible for changes to confidentiality practices and commitments. A formal process is used to communicate these changes to internal and external users, related parties, and vendors. Related party and vendor systems are subject to review as part of the vendor risk management process. Attestation reports (SOC 2 reports) are obtained and evaluated when available. Site	the review period to determine that the employees signed a confidentiality agreement to not disclose proprietary or confidential information, including client information, to unauthorized parties. Inquired of management and inspected relevant documentation to determine that management communicates the importance of Information Security through ongoing Information Security related training for employees, documenting and implementing Information Security policies, and having frequent discussions with employees regarding the critical nature of Information Security including individual responsibilities for data and systems security. Inquired of management to determine that the chief technology officer is responsible for changes to confidentiality practices and commitments and that a formal process is used to communicate these changes to internal and external users, related parties, and vendors. Inquired of management to determine that related party and vendor systems are subject to review as part of the vendor risk	No exceptions noted. No exceptions noted. No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC2.0 - COMMON CRITERIA RELATED TO COMMUNICATION AND INFORMATION

The criteria relevant to how the entity (i) uses relevant information, (ii) communicates internally, and (iii) communicates externally.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC2.3	COSO Principle 15: The entity communicates with external parties regarding matters affecting the functioning of internal control.	visits and other procedures are performed based on the entity's vendor management guidelines.	management process and that attestation reports (SOC 2 reports) are obtained and evaluated when available and/or site visits and other procedures are performed based on the entity's vendor management guidelines.	No exceptions noted.
		Policies and procedures are in place to communicate significant security events to external parties.	Inspected the policies and procedures to determine that policies and procedures are in place to communicate significant security events to external parties.	No exceptions noted.
		Policies and procedures are in place to guide personnel regarding sharing information with third parties.	Inspected the policies and procedures and the service level agreements to determine that the entity's policies included procedures to guide personnel regarding sharing information with third parties.	No exceptions noted.
		Procedures have been implemented to protect confidential information in the event that a disclosed confidentiality practice is discontinued or changed to be less restrictive and to communicate these changes to external parties.	Inspected confidentiality policies and procedures to determine that procedures have been implemented to protect confidential information in the event that a disclosed confidentiality practice is discontinued or changed to be less restrictive and to communicate these changes to external parties.	No exceptions noted.
		Policies and procedures are in place for identifying the system security requirements of authorized users.	Inspected the policies and procedures to determine that the entity's system security policies were established.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC2.0 - COMMON CRITERIA RELATED TO COMMUNICATION AND INFORMATION

The criteria relevant to how the entity (i) uses relevant information, (ii) communicates internally, and (iii) communicates externally.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		PROGRESS LEARNING has established operational requirements that support the achievement of service commitments, relevant laws and regulations, and other system requirements. Service commitments to customers are documented and communicated in customer agreements provided to user entities. Management has developed PROGRESS LEARNING's definition of system downtime and determined acceptance level criteria and how significant issues are communicated to external parties. Related party and vendor systems are subject to review as part of the vendor risk management process. Attestation reports (SOC 2 reports) are obtained and evaluated when available. Site visits and other procedures are performed based on the entity's vendor management guidelines. The chief technology officer is responsible for changes to confidentiality practices and commitments. A formal process is used to communicate these changes to internal and external users, related parties, and vendors.	Inspected a sample customer agreement to determine that service commitments to customers are documented and communicated in customer agreements provided to user entities. Inspected company documentation to determine that management has developed PROGRESS LEARNING's definition of system downtime and acceptance level criteria and how significant issues are communicated to external parties. Inquired of management to determine that related party and vendor systems are subject to review as part of the vendor risk management process and that attestation reports (SOC 2 reports) are obtained and evaluated when available and/or site visits and other procedures are performed based on the entity's vendor management guidelines. Inquired of management to determine that the chief technology officer is responsible for changes to confidentiality practices and commitments and that a formal process is used to communicate these changes to internal and	No exceptions noted. No exceptions noted. No exceptions noted. No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC2.0 - COMMON CRITERIA RELATED TO COMMUNICATION AND INFORMATION

The criteria relevant to how the entity (i) uses relevant information, (ii) communicates internally, and (iii) communicates externally.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Prior to collecting personal information of external users, a privacy policy is provided that may include the purpose and use of the personal information, including detailed use, ability to opt-out, enhancement (enrichment), sharing, disclosure, access, security, retention, breach notification requirements, and disposal of personal information.	external users, related parties, and vendors. Inspected policies to determine that if personal information of external users is collected, a privacy policy is provided that may include the purpose and use of the collection of their personal information, including detailed use, ability to opt-out, enhancement (enrichment), sharing, disclosure, access, security, retention, breach notification requirements, and disposal of personal information.	No exceptions noted.
		System descriptions of hosted user applications are made available to authorized external users that delineate the boundaries of the system and describe significant system components as well as the purpose and design of the system. The system description of the hosted user application is made available to external users via ongoing communications with customers or via the PROGRESS LEARNING website.	Inspected the system descriptions of hosted user applications to determine that the system descriptions of hosted user applications are made available to authorized external users that delineate the boundaries of the system and describe significant system components as well as the purpose and design of the system.	No exceptions noted.
			Inquired of management to determine that the system description of the hosted user application is made available to external users via ongoing communications with customers or via the PROGRESS LEARNING website.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC3.0 - COMMON CRITERIA RELATED TO RISK ASSESSMENT

The criteria relevant to how the entity (i) specifies suitable objectives, (ii) identifies and analyzes risk, and (iii) assess fraud risk.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC3.1	COSO Principle 6: The entity specifies objectives with sufficient clarity to enable the identification and assessment of risks relating to objectives.	A formal risk assessment is performed on an annual basis. Company objectives are determined, and risks and mitigation strategies are identified, evaluated, and formally documented in memo form. The risk assessment includes, but is not limited to, the following areas: • Data security (company data and client data). • Potential fraud and misconduct including how management and staff might engage in inappropriate actions from the use of IT and access to information. • Regulatory, economic, and physical environment in which the company operates. • Business environment, including industry, competitors, regulatory environment, and consumers. • Potential impact of new business lines, dramatically altered business lines, acquired or divested business operations on the system of internal control, rapid growth, changing reliance on foreign geographies, and new technologies. • Management and respective attitudes and philosophies on the system of internal control. • Vendor and business partner relationships including third-party data centers. • Systems and technology environment.	Inspected the annual risk assessment documentation to determine that a formal risk assessment was performed during the review period and that company objectives, identified risks, and mitigation strategies were formally documented.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC3.0 - COMMON CRITERIA RELATED TO RISK ASSESSMENT

The criteria relevant to how the entity (i) specifies suitable objectives, (ii) identifies and analyzes risk, and (iii) assess fraud risk.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC3.2	COSO Principle 7: The entity identifies risks to the achievement of its objectives across the entity and analyzes risks as a basis for determining how the risks should be managed.	Management stays current on regulatory compliance or operational trends affecting the services provided by attending trade shows, utilizing trade and regulatory publications, journals, online news feeds or government sites, or belonging to industry associations.	Inquired of management and inspected company documentation of trade show agendas, online sites, publications, or association membership literature to determine that management stays current on regulatory compliance or operational trends affecting the services provided.	No exceptions noted.
		Policies and procedures are in place to guide personnel regarding assessing risks on a periodic basis.	Inspected the policies and procedures manual to determine that the entity's policies included procedures regarding assessing risks on a periodic basis.	No exceptions noted.
		Policies and procedures are in place to guide personnel regarding identifying and mitigating security breaches and other incidents.	Inspected the policies and procedures to determine that the entity's policies included procedures regarding identifying and mitigating system security and related security breaches and other incidents.	No exceptions noted.
		A formal risk assessment is performed on an annual basis. Company objectives are determined, and risks and mitigation strategies are identified, evaluated, and formally documented in memo form. The risk assessment includes, but is not limited to, the following areas: • Data security (company data and client data). • Potential fraud and misconduct including how management and staff	Inspected the annual risk assessment documentation to determine that a formal risk assessment was performed during the review period and that company objectives, identified risks, and mitigation strategies were formally documented.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC3.0 - COMMON CRITERIA RELATED TO RISK ASSESSMENT

The criteria relevant to how the entity (i) specifies suitable objectives, (ii) identifies and analyzes risk, and (iii) assess fraud risk.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		might engage in inappropriate actions from the use of IT and access to information. - Regulatory, economic, and physical environment in which the company operates. - Business environment, including industry, competitors, regulatory environment, and consumers. - Potential impact of new business lines, dramatically altered business lines, acquired or divested business operations on the system of internal control, rapid growth, changing reliance on foreign geographies, and new technologies. - Management and respective attitudes and philosophies on the system of internal control. - Vendor and business partner relationships including third-party data centers. - Systems and technology environment. Management stays current on regulatory compliance or operational trends affecting the services provided by attending trade shows, utilizing trade and regulatory publications, journals, online news feeds or government sites, or belonging to industry associations.	Inquired of management and inspected company documentation of trade show agendas, online sites, publications, or association membership literature to determine that management stays current on regulatory compliance or operational trends affecting the services provided.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC3.0 - COMMON CRITERIA RELATED TO RISK ASSESSMENT

The criteria relevant to how the entity (i) specifies suitable objectives, (ii) identifies and analyzes risk, and (iii) assess fraud risk.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Production system backup data is replicated to a secondary geographically dispersed data center for disaster recovery purposes.	Inspected the backup configurations to determine that production system backup data is replicated to a secondary geographically dispersed data center for disaster recovery purposes.	No exceptions noted.
		Redundant servers are in place for critical production applications.	Inquired of management to determine that redundant servers are in place for critical production applications.	No exceptions noted.
			Observed redundant system infrastructure and the network configuration documentation to confirm server redundancy for critical production applications.	No exceptions noted.
		Critical production equipment is maintained under warranty and maintenance or Service Level Agreements (SLAs) with 3 rd party vendors.	Inspected current agreements with third-party vendors to determine that critical production equipment is maintained under warranty and maintenance or service level agreements with 3 rd party vendors.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY**CC3.0 - COMMON CRITERIA RELATED TO RISK ASSESSMENT**

The criteria relevant to how the entity (i) specifies suitable objectives, (ii) identifies and analyzes risk, and (iii) assess fraud risk.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC3.3	COSO Principle 8: The entity considers the potential for fraud in assessing risks to the achievement of objectives.	A formal risk assessment is performed on an annual basis. Company objectives are determined, and risks and mitigation strategies are identified, evaluated, and formally documented in memo form. The risk assessment includes, but is not limited to, the following areas: • Data security (company data and client data). • Potential fraud and misconduct including how management and staff might engage in inappropriate actions from the use of IT and access to information. • Regulatory, economic, and physical environment in which the company operates. • Business environment, including industry, competitors, regulatory environment, and consumers. • Potential impact of new business lines, dramatically altered business lines, acquired or divested business operations on the system of internal control, rapid growth, changing reliance on foreign geographies, and new technologies. • Management and respective attitudes and philosophies on the system of internal control. • Vendor and business partner relationships including third-party data centers. • Systems and technology environment.	Inspected the annual risk assessment documentation to determine that a formal risk assessment was performed during the review period and that company objectives, identified risks, and mitigation strategies were formally documented.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC3.0 - COMMON CRITERIA RELATED TO RISK ASSESSMENT

The criteria relevant to how the entity (i) specifies suitable objectives, (ii) identifies and analyzes risk, and (iii) assess fraud risk.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC3.4	COSO Principle 9: The entity identifies and assesses changes that could significantly impact the system of internal control.	A formal risk assessment is performed on an annual basis. Company objectives are determined, and risks and mitigation strategies are identified, evaluated, and formally documented in memo form. The risk assessment includes, but is not limited to, the following areas: • Data security (company data and client data). • Potential fraud and misconduct including how management and staff might engage in inappropriate actions from the use of IT and access to information. • Regulatory, economic, and physical environment in which the company operates. • Business environment, including industry, competitors, regulatory environment, and consumers. • Potential impact of new business lines, dramatically altered business lines, acquired or divested business operations on the system of internal control, rapid growth, changing reliance on foreign geographies, and new technologies. • Management and respective attitudes and philosophies on the system of internal control. • Vendor and business partner relationships including third-party data centers. • Systems and technology environment.	Inspected the annual risk assessment documentation to determine that a formal risk assessment was performed during the review period and that company objectives, identified risks, and mitigation strategies were formally documented.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC4.0 - COMMON CRITERIA RELATED TO MONITORING ACTIVITIES

The criteria relevant to how the entity (i) conducts ongoing and/or separate evaluations, and (ii) evaluates and communicates deficiencies.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC4.1	COSO Principle 16: The entity selects, develops, and performs ongoing and/or separate evaluations to ascertain whether the components of internal control are present and functioning.	Policies and procedures are in place to guide personnel regarding assessing risks on a periodic basis.	Inspected the policies and procedures manual to determine that the entity's policies included procedures regarding assessing risks on a periodic basis.	No exceptions noted.
		Management periodically performs internal security assessments, including reviews of server logs and other critical items.	Inspected results from internal security assessments performed during the review period to determine that management periodically performs internal security assessments.	No exceptions noted.
		Management has developed PROGRESS LEARNING's definition of system downtime and determined acceptance level criteria and how significant issues are communicated to external parties.	Inspected company documentation to determine that management has developed PROGRESS LEARNING's definition of system downtime and acceptance level criteria and how significant issues are communicated to external parties.	No exceptions noted.
		Third-party enterprise monitoring applications are used to monitor system downtime and operations issues to help ensure that system downtime and performance does not exceed predefined levels. This includes monitoring of both critical network and server hardware, as well as processes and services: • System uptime and downtime • Critical performance metrics (CPU utilization, storage, etc.). Problems with critical systems are remediated as necessary.	Inspected the enterprise monitoring applications to determine that third-party enterprise monitoring applications are used to monitor performance criteria for critical server and network equipment.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC4.0 - COMMON CRITERIA RELATED TO MONITORING ACTIVITIES

The criteria relevant to how the entity (i) conducts ongoing and/or separate evaluations, and (ii) evaluates and communicates deficiencies.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
			Inspected the metrics tracking reports to determine that system downtime and operations issues were monitored.	No exceptions noted.
			Inspected a sample of Slack alerts to determine that problems with critical systems are remediated as necessary	No exceptions noted.
		The enterprise monitoring application is configured to send alert notifications to operations personnel when predefined metrics are exceeded on monitored network devices. Alerts are communicated via SMS text or email to appropriate support personnel.	Inspected the enterprise monitoring application configuration screens to determine that performance thresholds are set, and alerts are communicated if pre-determined metrics are reached.	No exceptions noted.
		Management utilizes vulnerability assessment tools (VAT) to help determine vulnerability risks and evaluates and takes action on issues identified in the report.	Inspected vulnerability assessment tools, configurations and test reports generated to determine that management utilizes vulnerability assessment tools to help determine vulnerability risks.	No exceptions noted.
			Inspected a sample of closed tickets remediating issues in the most recent report to determine that management evaluates and takes action on issues identified in the report.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC4.0 - COMMON CRITERIA RELATED TO MONITORING ACTIVITIES

The criteria relevant to how the entity (i) conducts ongoing and/or separate evaluations, and (ii) evaluates and communicates deficiencies.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		PROGRESS LEARNING periodically contracts with a third-party network security company to conduct external network penetration tests and vulnerability assessments. A report is generated and reviewed by management, and tickets are generated for any necessary remedial action.	Inquired of management to determine that PROGRESS LEARNING periodically contracts with a third-party network security company to conduct external network penetration tests and vulnerability assessments and that management reviews any reports and generates tickets for any necessary remedial action.	No exceptions noted.
			Inspected report from a sample of external network penetration tests and vulnerability assessments during the review period to determine that a report is generated and reviewed by management.	No exceptions noted.
			Inspected a sample of tickets or other internal communications during the review period to determine tickets are generated for any necessary remedial action.	No exceptions noted.
		Certain events are logged and maintained for management review.	Inspected the event monitoring configurations, and event logs to determine that certain events were logged and maintained for management review.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC4.0 - COMMON CRITERIA RELATED TO MONITORING ACTIVITIES

The criteria relevant to how the entity (i) conducts ongoing and/or separate evaluations, and (ii) evaluates and communicates deficiencies.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		The production servers log certain server-level events for ad hoc auditing and review purposes. Certain application events are logged and maintained for management review. PROGRESS LEARNING utilizes the services and controls of a third-party data center for housing critical production computer servers, applications, and networking equipment. The third-party data center is responsible for the controls relevant to the completeness and accuracy of specified reports provided to and used by PROGRESS LEARNING. PROGRESS LEARNING management reviews the SOC audit report of the third-party data center annually and documents the results of the review of the SOC audit report in a memo.	Inquired of management to determine that the server logs certain server-level events for ad hoc auditing and review purposes. Inspected a sample of server logs to determine that the server logs certain server-level events for ad hoc auditing and review purposes. Inspected application logs to determine that certain Web server events were logged and maintained for management review. Inspected the most recent SOC audit report for the third-party data center to determine that PROGRESS LEARNING utilizes relevant reports provided by the third-party data center. Inspected management's memo to determine that PROGRESS LEARNING management documents the results of the review of the SOC report in a memo.	No exceptions noted. No exceptions noted. No exceptions noted. No exceptions noted. No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC4.0 - COMMON CRITERIA RELATED TO MONITORING ACTIVITIES

The criteria relevant to how the entity (i) conducts ongoing and/or separate evaluations, and (ii) evaluates and communicates deficiencies.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC4.2	COSO Principle 17: The entity evaluates and communicates internal control deficiencies in a timely manner to those parties responsible for taking corrective action, including senior management and the board of directors, as appropriate.	Security policies and procedures are in place and periodically reviewed by a designated individual or group to ensure that potential internal control deficiencies are evaluated and mitigated.	Inspected the policies and procedures manual to determine that the entity's system security policies and procedures are in place and periodically reviewed by a designated individual or group to ensure that potential internal control deficiencies are evaluated and mitigated.	No exceptions noted.
		Management has developed PROGRESS LEARNING's definition of system downtime and determined acceptance level criteria and how significant issues are communicated to external parties.	Inspected company documentation to determine that management has developed PROGRESS LEARNING's definition of system downtime and acceptance level criteria and how significant issues are communicated to external parties.	No exceptions noted.
		Third-party enterprise monitoring applications are used to monitor system downtime and operations issues to help ensure that system downtime and performance does not exceed predefined levels. This includes monitoring of both critical network and server hardware, as well as processes and services: • System uptime and downtime • Critical performance metrics (CPU utilization, storage, etc.). Problems with critical systems are remediated as necessary.	Inspected the enterprise monitoring applications to determine that third-party enterprise monitoring applications are used to monitor performance criteria for critical server and network equipment.	No exceptions noted.
			Inspected the metrics tracking reports to determine that system downtime and operations issues were monitored.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC4.0 - COMMON CRITERIA RELATED TO MONITORING ACTIVITIES

The criteria relevant to how the entity (i) conducts ongoing and/or separate evaluations, and (ii) evaluates and communicates deficiencies.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
			Inspected a sample of Slack alerts to determine that problems with critical systems are remediated as necessary	No exceptions noted.
		The enterprise monitoring application is configured to send alert notifications to operations personnel when predefined metrics are exceeded on monitored network devices. Alerts are communicated via SMS text or email to appropriate support personnel.	Inspected the enterprise monitoring application configuration screens to determine that performance thresholds are set, and alerts are communicated if pre-determined metrics are reached.	No exceptions noted.
		Management utilizes vulnerability assessment tools (VAT) to help determine vulnerability risks and evaluates and takes action on issues identified in the report.	Inspected vulnerability assessment tools, configurations and test reports generated to determine that management utilizes vulnerability assessment tools to help determine vulnerability risks.	No exceptions noted.
			Inspected a sample of closed tickets remediating issues in the most recent report to determine that management evaluates and takes action on issues identified in the report.	No exceptions noted.
		Management periodically performs internal security assessments, including reviews of server logs and other critical items.	Inspected results from internal security assessments performed during the review period to determine that management periodically performs internal security assessments.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC4.0 - COMMON CRITERIA RELATED TO MONITORING ACTIVITIES

The criteria relevant to how the entity (i) conducts ongoing and/or separate evaluations, and (ii) evaluates and communicates deficiencies.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		PROGRESS LEARNING periodically contracts with a third-party network security company to conduct external network penetration tests and vulnerability assessments. A report is generated and reviewed by management, and tickets are generated for any necessary remedial action.	Inquired of management to determine that PROGRESS LEARNING periodically contracts with a third-party network security company to conduct external network penetration tests and vulnerability assessments and that management reviews any reports and generates tickets for any necessary remedial action.	No exceptions noted.
			Inspected report from a sample of external network penetration tests and vulnerability assessments during the review period to determine that a report is generated and reviewed by management.	No exceptions noted.
			Inspected a sample of tickets or other internal communications during the review period to determine tickets are generated for any necessary remedial action.	No exceptions noted.
		Certain events are logged and maintained for management review.	Inspected the event monitoring configurations, and event logs to determine that certain events were logged and maintained for management review.	No exceptions noted.
		The production servers log certain server-level events for ad hoc auditing and review purposes.	Inquired of management to determine that the server logs certain server-level events for ad hoc auditing and review purposes.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY**CC4.0 - COMMON CRITERIA RELATED TO MONITORING ACTIVITIES**

The criteria relevant to how the entity (i) conducts ongoing and/or separate evaluations, and (ii) evaluates and communicates deficiencies.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Certain application events are logged and maintained for management review.	Inspected a sample of server logs to determine that the server logs certain server-level events for ad hoc auditing and review purposes. Inspected application logs to determine that certain Web server events were logged and maintained for management review.	No exceptions noted. No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC5.0 - COMMON CRITERIA RELATED TO CONTROL ACTIVITIES

The criteria relevant to how the entity (i) selects and develops control activities, (ii) selects and develops general controls over technology, and (iii) deploys through policies and procedures.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC5.1	COSO Principle 10: The entity selects and develops control activities that contribute to the mitigation of risks to the achievement of objectives to acceptable levels.	Policies and procedures are in place to guide personnel regarding assessing risks on a periodic basis.	Inspected the policies and procedures manual to determine that the entity's policies included procedures regarding assessing risks on a periodic basis.	No exceptions noted.
		Security policies and procedures are in place and periodically reviewed by a designated individual or group to ensure that potential internal control deficiencies are evaluated and mitigated.	Inspected the policies and procedures manual to determine that the entity's system security policies and procedures are in place and periodically reviewed by a designated individual or group to ensure that potential internal control deficiencies are evaluated and mitigated.	No exceptions noted.
		A formal risk assessment is performed on an annual basis. Company objectives are determined, and risks and mitigation strategies are identified, evaluated, and formally documented in memo form. The risk assessment includes, but is not limited to, the following areas: • Data security (company data and client data). • Potential fraud and misconduct including how management and staff might engage in inappropriate actions from the use of IT and access to information. • Regulatory, economic, and physical environment in which the company operates.	Inspected the annual risk assessment documentation to determine that a formal risk assessment was performed during the review period and that company objectives, identified risks, and mitigation strategies were formally documented.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC5.0 - COMMON CRITERIA RELATED TO CONTROL ACTIVITIES

The criteria relevant to how the entity (i) selects and develops control activities, (ii) selects and develops general controls over technology, and (iii) deploys through policies and procedures.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		• Business environment, including industry, competitors, regulatory environment, and consumers. • Potential impact of new business lines, dramatically altered business lines, acquired or divested business operations on the system of internal control, rapid growth, changing reliance on foreign geographies, and new technologies. • Management and respective attitudes and philosophies on the system of internal control. • Vendor and business partner relationships including third-party data centers. • Systems and technology environment.		
		Security monitoring applications and manual reviews are utilized to monitor and analyze the in-scope systems for possible or actual security breaches. (i.e., Security Information and Event Management)	Inspected the monitoring system reports, tickets, and e-mail notifications sent to the information security manager during the review period to determine that the commercial network monitoring tool monitored the network ID/PS, analyzed network events, and reported possible or actual network security breaches to information security personnel.	No exceptions noted.
		Management periodically performs internal security assessments, including reviews of server logs and other critical items.	Inspected results from internal security assessments performed during the review period to determine that management periodically performs internal security assessments.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC5.0 - COMMON CRITERIA RELATED TO CONTROL ACTIVITIES

The criteria relevant to how the entity (i) selects and develops control activities, (ii) selects and develops general controls over technology, and (iii) deploys through policies and procedures.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC5.2	COSO Principle 11: The entity also selects and develops general control activities over technology to support the achievement of objectives.	Policies and procedures are in place to guide personnel regarding assessing risks on a periodic basis.	Inspected the policies and procedures manual to determine that the entity's policies included procedures regarding assessing risks on a periodic basis.	No exceptions noted.
		Security policies and procedures are in place and periodically reviewed by a designated individual or group to ensure that potential internal control deficiencies are evaluated and mitigated.	Inspected the policies and procedures manual to determine that the entity's system security policies and procedures are in place and periodically reviewed by a designated individual or group to ensure that potential internal control deficiencies are evaluated and mitigated.	No exceptions noted.
		Policies and procedures are in place to ensure that design, acquisition, implementation, configuration, modification, and management of infrastructure and software are consistent with defined system security policies to enable authorized access and to prevent unauthorized access.	Inspected relevant policies and procedures to determine that policies and procedures are in place to ensure that design, acquisition, implementation, configuration, modification, and management of infrastructure and software are consistent with defined system security policies to enable authorized access and to prevent unauthorized access.	No exceptions noted.
		Policies and procedures are in place to ensure that change management processes are initiated when deficiencies in the design or operating effectiveness of controls are identified during system operation and monitoring.	Observed and inspected relevant policies and procedures to determine that policies and procedures are in place to ensure that change management processes are initiated when deficiencies in the design or operating effectiveness of controls	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC5.0 - COMMON CRITERIA RELATED TO CONTROL ACTIVITIES

The criteria relevant to how the entity (i) selects and develops control activities, (ii) selects and develops general controls over technology, and (iii) deploys through policies and procedures.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Policies and procedures are in place to guide personnel regarding testing, evaluating, and authorizing system components before implementation. A software development life cycle is utilized to designate milestones that must be achieved throughout the development and testing process. Program development is performed in a distinct development environment that is physically separated from the production environment. Development takes place on developers' local machines. Version control software is utilized to maintain and control access to current and prior versions of application source code, and the associated reporting and logging functions.	are identified during system operation and monitoring. Inspected the policies and procedures related to testing, evaluating, and authorizing before implementation of components. Inspected software development life cycle documentation to determine that a software development life cycle was utilized to designate milestones that must be achieved throughout the development and testing process. Observed the location of the servers for each environment to determine that development environment is physically separated from the production environment. Inspected the checkout process from the version control software and a sample of local development machines to determine that development takes place on developers' local machines. Inspected and observed the version control software to determine that version control software is utilized to maintain and control access to current and prior versions of application code.	No exceptions noted. No exceptions noted. No exceptions noted. No exceptions noted. No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC5.0 - COMMON CRITERIA RELATED TO CONTROL ACTIVITIES

The criteria relevant to how the entity (i) selects and develops control activities, (ii) selects and develops general controls over technology, and (iii) deploys through policies and procedures.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Access to version control software is restricted based upon job responsibilities. Access is restricted to approved positions only.	Inspected access rights listing to determine that access to version control software is restricted based upon job responsibilities, and that access is restricted to approved positions only.	No exceptions noted.
		Documented change requests are completed for bug fixes, enhancements and new development.	Inspected a sample of product changes from the review period for entries in the tracking system to determine that requests were completed for bug fixes, enhancements and new development.	No exceptions noted.
		A ticket or change management form is completed and properly approved before core changes are made to production application code.	Inspected a sample of tickets or change management forms to determine that a ticket or change management form is completed and properly approved before core changes are made to production application code.	No exceptions noted.
		Change management software is utilized to manage application changes, and the associated reporting and logging functions.	Inspected and observed the application to determine that change management software is utilized to manage application changes, and the associated reporting and logging functions.	No exceptions noted.
		Changes to source code results in the creation of a new version of the application code. If necessary, changes can be rolled back to prior versions of the application code.	Inspected a sample of versioning history to determine that changes to source code resulted in the creation of a new version of the application code.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC5.0 - COMMON CRITERIA RELATED TO CONTROL ACTIVITIES

The criteria relevant to how the entity (i) selects and develops control activities, (ii) selects and develops general controls over technology, and (iii) deploys through policies and procedures.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Logs are utilized to maintain and record changes to manage and monitor development and maintenance activities.	Inspected a sampling of logs to determine that logs are utilized to maintain and record changes to manage and monitor development and maintenance activities.	No exceptions noted.
		The quality assurance and testing efforts are performed in a distinct test environment that is logically separated from the production environment.	Observed the location of the servers for each environment to determine that quality assurance and test environments are logically separated from the production environment.	No exceptions noted.
		Access to the quality assurance testing environment is restricted based upon job responsibilities.	Inspected access rights listing to determine that access to the quality assurance testing environment is restricted based upon job responsibilities.	No exceptions noted.
		Application testing takes place at several different phases of the development cycle: • Unit Testing during development. • QA Testing, including regression testing. • User Acceptance Testing (UAT) during staging.	Inquired of management to determine that application testing takes place at different phases of the development cycle.	No exceptions noted.
		Quality assurance personnel perform quality assurance testing for application changes and update the change request ticket history to indicate approval of the test results prior to migration to the production environment.	Inspected change request forms and internal release notices for changes promoted to production during the review period to determine that quality assurance personnel perform quality assurance testing for application changes and update the change request ticket history to indicate	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC5.0 - COMMON CRITERIA RELATED TO CONTROL ACTIVITIES

The criteria relevant to how the entity (i) selects and develops control activities, (ii) selects and develops general controls over technology, and (iii) deploys through policies and procedures.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		User acceptance testing is performed and signed off on by stakeholders before migration to the production environment. Informal management approvals are obtained before application code changes are migrated to the production environment. New code is deployed to the production environment after business hours. Hot fixes are deployed immediately. Critical hardware infrastructure changes follow a structured change methodology, including testing of hardware changes where necessary. A ticketing system is utilized to manage systems infrastructure issues and changes. Tickets are assigned to support personnel based on the nature of the ticket.	approval of the test results prior to migration to the production environment. Inspected stakeholder approvals to determine that user acceptance testing is performed and signed off on by stakeholders before migration to the production environment. Inquired of management to determine that informal management approvals were obtained before application code changes were migrated to the production environment. Inquired of management to determine that new code is deployed to the production environment after business hours, while hot fixes are deployed immediately. Inspected the infrastructure change management policies and procedures to determine that critical hardware infrastructure changes follow a structured change methodology. Inspected logs from the ticketing system showing closed tickets to determine that a ticketing system was utilized to manage systems infrastructure issues and that	No exceptions noted. No exceptions noted. No exceptions noted. No exceptions noted. No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC5.0 - COMMON CRITERIA RELATED TO CONTROL ACTIVITIES

The criteria relevant to how the entity (i) selects and develops control activities, (ii) selects and develops general controls over technology, and (iii) deploys through policies and procedures.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		A Slack approval is obtained before core changes are made to the production systems environment. A standard hardened template for virtualized environments is utilized for installation and maintenance of certain critical virtual machines. Critical production equipment is maintained under warranty and maintenance or Service Level Agreements (SLAs) with 3rd party vendors. A management-approved methodology is utilized to monitor operating system patch releases, distribute patches to relevant devices and apply the patches to the device.	tickets were assigned to support personnel based on the nature of the ticket. Inspected a sample of Slack approvals to determine that Slack approvals are obtained before core changes are made to production systems environment. Inspected the virtualization configurations to determine that a standard template is used for installation and maintenance of certain critical PROGRESS LEARNING virtual machines. Inspected current agreements with third-party vendors to determine that critical production equipment is maintained under warranty and maintenance or service level agreements with 3rd party vendors. Inquired of management to determine that a methodology is utilized to monitor operating system patch releases, distribute patches to relevant devices and apply the patches to the device. Inspected a sample of servers and workstations to determine that a management-approved methodology is utilized to monitor operating system patch releases,	No exceptions noted. No exceptions noted. No exceptions noted. No exceptions noted. No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC5.0 - COMMON CRITERIA RELATED TO CONTROL ACTIVITIES

The criteria relevant to how the entity (i) selects and develops control activities, (ii) selects and develops general controls over technology, and (iii) deploys through policies and procedures.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Infrastructure changes, patches and upgrades to critical services are tested by the technical support department before being applied to a production server.	distribute patches to relevant devices and apply the patches to the device. Inquired of management to determine that infrastructure changes, patches and upgrades to critical services are tested by the technical support department after hours before being introduced to a production server. Inspected hardware update logs to determine that patches and upgrades to critical services are tested by the technical support department before being introduced to a production server.	No exceptions noted. No exceptions noted.
		PROGRESS LEARNING utilizes the services and controls of a third-party data center for housing critical production computer servers, applications, and networking equipment. The third-party data center is responsible for the general IT controls relevant to its application development.	Inspected the most recent SOC audit report for the third-party data center to determine that the third-party data center is responsible for the general IT controls relevant to its application development.	No exceptions noted.
		PROGRESS LEARNING utilizes the services and controls of a third-party data center for housing critical production computer servers, applications, and networking equipment. The third-party data center is responsible for the general IT controls relevant to its change management.	Inspected the most recent SOC audit report for the third-party data center to determine that the third-party data center is responsible for the general IT controls relevant to its change management.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC5.0 - COMMON CRITERIA RELATED TO CONTROL ACTIVITIES

The criteria relevant to how the entity (i) selects and develops control activities, (ii) selects and develops general controls over technology, and (iii) deploys through policies and procedures.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		PROGRESS LEARNING management reviews the SOC audit report of the third-party data center annually and documents the results of the review of the SOC audit report in a memo.	Inspected management's memo to determine that PROGRESS LEARNING management documents the results of the review of the SOC report in a memo.	No exceptions noted.
		Security monitoring applications and manual reviews are utilized to monitor and analyze the in-scope systems for possible or actual security breaches. (i.e., Security Information and Event Management)	Inspected the monitoring system reports, tickets, and e-mail notifications sent to the information security manager during the review period to determine that the commercial network monitoring tool monitored the network ID/PS, analyzed network events, and reported possible or actual network security breaches to information security personnel.	No exceptions noted.
		Management utilizes vulnerability assessment tools (VAT) to help determine vulnerability risks and evaluates and takes action on issues identified in the report.	Inspected vulnerability assessment tools, configurations and test reports generated to determine that management utilizes vulnerability assessment tools to help determine vulnerability risks.	No exceptions noted.
			Inspected a sample of closed tickets remediating issues in the most recent report to determine that management evaluates and takes action on issues identified in the report.	No exceptions noted.
		Management periodically performs internal security assessments, including reviews of server logs and other critical items.	Inspected results from internal security assessments performed during the review period to determine that management	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC5.0 - COMMON CRITERIA RELATED TO CONTROL ACTIVITIES

The criteria relevant to how the entity (i) selects and develops control activities, (ii) selects and develops general controls over technology, and (iii) deploys through policies and procedures.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		PROGRESS LEARNING periodically contracts with a third-party network security company to conduct external network penetration tests and vulnerability assessments. A report is generated and reviewed by management, and tickets are generated for any necessary remedial action.	periodically performs internal security assessments. Inquired of management to determine that PROGRESS LEARNING periodically contracts with a third-party network security company to conduct external network penetration tests and vulnerability assessments and that management reviews any reports and generates tickets for any necessary remedial action. Inspected report from a sample of external network penetration tests and vulnerability assessments during the review period to determine that a report is generated and reviewed by management. Inspected a sample of tickets or other internal communications during the review period to determine tickets are generated for any necessary remedial action.	No exceptions noted. No exceptions noted. No exceptions noted.
		User access reviews are performed monthly and documented to verify that accounts are assigned to authorized personnel.	Inspected a sample of documented monthly user access reviews performed during the review period to determine that user access reviews were performed monthly and documented to verify that accounts are assigned to authorized personnel.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC5.0 - COMMON CRITERIA RELATED TO CONTROL ACTIVITIES

The criteria relevant to how the entity (i) selects and develops control activities, (ii) selects and develops general controls over technology, and (iii) deploys through policies and procedures.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Administrative access reviews are performed annually and documented to verify that administrative access is assigned to authorized personnel only.	Inspected a sample of documented annual administrative access reviews performed during the review period to determine that administrative access reviews were performed annually and documented to verify that administrative access is assigned to authorized personnel only.	No exceptions noted.
		Firewall systems are in place to handle data flow between external parties and cloud hosted networks. External traffic originating from the Internet must pass through a firewall system to communicate with production servers. No direct conversations originating from the Internet pass directly through to the cloud private networks.	Inspected the firewall system rule sets to determine that firewall systems are in place to handle data flow between external parties and the cloud hosted networks.	No exceptions noted.
		PROGRESS LEARNING utilizes cloud firewall services at several levels: • Web Application Firewall (WAF) • Private Networks • Instance-level access control lists (ACLs) • Load Balancers.	Inquired of management to determine that PROGRESS LEARNING utilizes cloud firewall services at several levels as indicated.	No exceptions noted.
		Load balancers and private networks are utilized to isolate production instances from public access.	Inquired of management to determine that load balancers and private networks are utilized to isolate production instances from public access.	No exceptions noted.
			Inspected cloud provider's configuration to determine that load balancers and private networks are utilized to isolate internal production instances from public access.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC5.0 - COMMON CRITERIA RELATED TO CONTROL ACTIVITIES

The criteria relevant to how the entity (i) selects and develops control activities, (ii) selects and develops general controls over technology, and (iii) deploys through policies and procedures.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		A Web Application Firewall (WAF) is utilized to protect web applications from common web exploits that could affect application availability, compromise security, or consume excessive resources.	Inspected cloud provider's configuration to determine that a Web Application Firewall is utilized to protect web applications from common web exploits that could affect application availability, compromise security, or consume excessive resources.	No exceptions noted.
		Instance-level access control lists are utilized to control both inbound and outbound traffic to cloud hosted virtual instances and employ the following features: • Stateful packet inspection. • Ports are configured to allow only specific types of traffic between certain destinations. All unused ports are blocked. • Configured to deny all traffic that is not specifically authorized in the rule set.	Inspected instance-level access control list configurations and cloud provider literature to determine that instance-level access control lists are utilized to filter internet traffic based on content and destination site address and that stateful packet inspection is utilized.	No exceptions noted.
			Inspected the instance-level access control list configuration to determine that instance-level access control lists are configured to allow only specific types of traffic between certain destinations and that unused ports are disabled.	No exceptions noted.
			Inspected cloud provider literature to determine that instance-level access control lists deny traffic that is not specifically authorized in the rule set.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC5.0 - COMMON CRITERIA RELATED TO CONTROL ACTIVITIES

The criteria relevant to how the entity (i) selects and develops control activities, (ii) selects and develops general controls over technology, and (iii) deploys through policies and procedures.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Instance-level access control lists on cloud hosted virtual instances are configured with whitelists to trust IP addresses or IP ranges. The whitelists are utilized for limiting and controlling access only to trusted users to certain services or applications.	Inspected the instance-level access control list configurations to determine that instance-level access control lists are configured with whitelists to limit and control access only to trusted users to certain services or applications.	No exceptions noted.
		PROGRESS LEARNING utilizes the security services of the cloud provider to absorb DoS/DDoS attacks and to help protect public facing applications from common exploits that could affect application availability, compromise security, or consume excessive resources.	Inquired of management to determine that PROGRESS LEARNING utilizes the security services of the cloud provider to absorb DoS/DDoS attacks and to help protect public facing applications from common exploits that could affect application availability, compromise security, or consume excessive resources.	No exceptions noted.
			Inspected the cloud provider configuration and literature to determine that PROGRESS LEARNING utilizes the security services of the cloud provider to absorb DoS/DDoS attacks and to help protect public facing applications from common exploits that could affect application availability, compromise security, or consume excessive resources.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC5.0 - COMMON CRITERIA RELATED TO CONTROL ACTIVITIES

The criteria relevant to how the entity (i) selects and develops control activities, (ii) selects and develops general controls over technology, and (iii) deploys through policies and procedures.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		PROGRESS LEARNING utilizes the Intrusion Detection System (IDS) security services of the cloud provider to provide managed threat detection that continuously monitors for malicious or unauthorized behavior to help protect cloud accounts and workloads.	Inspected the cloud provider configuration and literature to determine that PROGRESS LEARNING utilizes the IDS security services of the cloud provider to provide managed threat detection that continuously monitors for malicious or unauthorized behavior to help protect cloud accounts and workloads.	No exceptions noted.
		Management maintains a commercial general liability insurance policy with Technology Errors and Omissions Liability & Cyber coverage	Inspected insurance coverage policy declarations page to determine that management maintained a commercial general liability insurance policy with Technology Errors and Omissions Liability & Cyber coverage.	No exceptions noted.
		PROGRESS LEARNING has a documented Disaster Recovery plan and Business Continuity plan.	Inspected documented Disaster Recovery plan and Business Continuity plan to determine that PROGRESS LEARNING has a documented Disaster Recovery plan and Business Continuity plan.	No exceptions noted.
		An Incident Response plan is in place to ensure appropriate response to outages or security incidents in an organized and timely manner.	Inspected the incident response plan to determine that a plan is in place to ensure appropriate response to outages or security incidents.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC5.0 - COMMON CRITERIA RELATED TO CONTROL ACTIVITIES

The criteria relevant to how the entity (i) selects and develops control activities, (ii) selects and develops general controls over technology, and (iii) deploys through policies and procedures.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC5.3	COSO Principle 12: The entity deploys control activities through policies that establish what is expected and in procedures that put policies into action.	PROGRESS LEARNING's policies and procedures address controls over significant aspects of system operations. Policies and procedures addressed include: • security requirements for authorized users • data classification and associated protection, access rights, retention, and destruction requirements • risk assessment • access protection requirements • user provisioning and deprovisioning • responsibility and accountability for security • responsibility and accountability for system changes and maintenance • change management • complaint intake and resolution • security and other incidents identification, response, and mitigation • security training • handling of exceptions and situations not specifically addressed in policies • commitment and requirement identification and compliance measurement • information sharing and disclosure • communication of significant security events to external parties • disposal of confidential client information • secure disposal of media and equipment.	Inspected the policies and procedures to determine the policies and procedures addressed controls over significant aspects of the system operations.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC5.0 - COMMON CRITERIA RELATED TO CONTROL ACTIVITIES

The criteria relevant to how the entity (i) selects and develops control activities, (ii) selects and develops general controls over technology, and (iii) deploys through policies and procedures.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		PROGRESS LEARNING's security policies are reviewed and updated annually by senior management for consistency with the organization's risk mitigation strategy and updated as necessary for changes in the strategy. Management has considered the competence levels for particular jobs and translated required skills and knowledge levels into written job descriptions.	Inspected documentation of the annual review and update of the security policies to determine the policies are reviewed annually by senior management for consistency with the organization's risk mitigation strategy and updated as necessary for changes in the strategy. Inspected a sample of written job descriptions to determine that management had considered the competence levels for particular jobs and translated required skills and knowledge levels into written job descriptions.	No exceptions noted. No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC6.0 - COMMON CRITERIA RELATED TO LOGICAL AND PHYSICAL ACCESS CONTROLS

The criteria relevant to how an entity (i) restricts logical and physical access, (ii) provides and removes that access, and (iii) prevents unauthorized access.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC6.1	The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.	Procedures have been implemented related to confidentiality of inputs, data processing, and outputs which are consistent with the documented confidentiality policies.	Inspected confidentiality policies and procedures to determine that procedures have been implemented related to confidentiality of inputs, data processing, and outputs which are consistent with the documented confidentiality policies.	No exceptions noted.
		Users are required to authenticate via a unique user ID and password before being granted access to PROGRESS LEARNING Google Workspace domain. Multifactor authentication is enabled.	Inspected the Google Workspace domain authentication process to determine that users are required to authenticate via a unique user ID and password before being granted access to PROGRESS LEARNING Google Workspace domain and that multifactor authentication is enabled.	No exceptions noted.
		Google Workspace domain passwords must conform to the following requirements: - Enforce password history. - Minimum password length. - Complexity requirement enabled.	Inspected the network authentication configurations to determine that network domain passwords must conform to stated requirements.	No exceptions noted.
		User IDs are locked out (automatically suspended) after a designated number of invalid login attempts within a set time period. The account is then locked out of the system for a set time period, and a notification alert is triggered.	Inspected documentation to determine that user IDs are locked out after a designated number of invalid login attempts within a set time period, and that the account is then locked out of the system for a set time period, and a notification is triggered.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC6.0 - COMMON CRITERIA RELATED TO LOGICAL AND PHYSICAL ACCESS CONTROLS

The criteria relevant to how an entity (i) restricts logical and physical access, (ii) provides and removes that access, and (iii) prevents unauthorized access.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Users are assigned to pre-defined roles and access rights within all PROGRESS LEARNING systems: • Access to sensitive production server directories and files is restricted based on job responsibilities. • Users are granted variable access rights according to a rights authorization methodology. • Access to systems is granted on a "least privilege" basis, with employees acquiring access only to those systems necessary to perform their job functions.	Inquired of management to determine that users are assigned to pre-defined roles and access rights within all PROGRESS LEARNING production systems and that variable rights are assigned based on job responsibilities and least privilege.	No exceptions noted.
			Inspected the access rights listing to determine that users are assigned to variable, pre-defined roles and access rights within all PROGRESS LEARNING production systems.	No exceptions noted.
		Database and application server operating system account policies are controlled by a separate active directory.	Inquired of the network administrator regarding operating system account policies to determine that database and application server operating system account policies were controlled by a separate active directory.	No exceptions noted.
			Inspected a sample of application and database server configurations to determine that the database and application server operating system account policies were controlled by a separate active directory.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC6.0 - COMMON CRITERIA RELATED TO LOGICAL AND PHYSICAL ACCESS CONTROLS

The criteria relevant to how an entity (i) restricts logical and physical access, (ii) provides and removes that access, and (iii) prevents unauthorized access.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Production server users are required to authenticate via a unique user ID and password before being granted access to the production environment. Multifactor authentication is enabled.	Inspected the production network domain authentication process to determine that users are required to authenticate via a unique user ID and password before being granted access to the production environment and that multifactor authentication is enabled.	No exceptions noted.
		Production server users are granted variable access rights according to a rights authorization methodology.	Inspected the production server access rights to determine that production server users are granted variable access rights according to a rights authorization methodology.	No exceptions noted.
		Production domain passwords must conform to the following requirements: - Enforce password history. - Minimum password length. - Complexity requirement enabled.	Inspected the production domain authentication configurations to determine that production domain passwords must conform to stated requirements.	No exceptions noted.
		Management has segregated specific duties within the production environment for administering critical areas such as: - Network administration - Systems (including Active Directory) administration - Database administration - Development.	Inspected access rights listing to determine that management has segregated specific duties within the production environment for administering critical areas.	No exceptions noted.
		Application users are required to authenticate via an authorized unique account ID, user ID and password before being granted access to the production environment.	Inspected logon screens to determine that application users were required to authenticate via an authorized unique account ID, user ID and password before being granted access to the production environment.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC6.0 - COMMON CRITERIA RELATED TO LOGICAL AND PHYSICAL ACCESS CONTROLS

The criteria relevant to how an entity (i) restricts logical and physical access, (ii) provides and removes that access, and (iii) prevents unauthorized access.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Firewall systems are in place to handle data flow between external parties and cloud hosted networks. External traffic originating from the Internet must pass through a firewall system to communicate with production servers. No direct conversations originating from the Internet pass directly through to the cloud private networks. PROGRESS LEARNING utilizes the security services of the cloud provider to absorb DoS/DDoS attacks and to help protect public facing applications from common exploits that could affect application availability, compromise security, or consume excessive resources.	Inspected the firewall system rule sets to determine that firewall systems are in place to handle data flow between external parties and the cloud hosted networks. Inquired of management to determine that PROGRESS LEARNING utilizes the security services of the cloud provider to absorb DoS/DDoS attacks and to help protect public facing applications from common exploits that could affect application availability, compromise security, or consume excessive resources. Inspected the cloud provider configuration and literature to determine that PROGRESS LEARNING utilizes the security services of the cloud provider to absorb DoS/DDoS attacks and to help protect public facing applications from common exploits that could affect application availability, compromise security, or consume excessive resources.	No exceptions noted. No exceptions noted. No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC6.0 - COMMON CRITERIA RELATED TO LOGICAL AND PHYSICAL ACCESS CONTROLS

The criteria relevant to how an entity (i) restricts logical and physical access, (ii) provides and removes that access, and (iii) prevents unauthorized access.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		PROGRESS LEARNING utilizes the Intrusion Detection System (IDS) security services of the cloud provider to provide managed threat detection that continuously monitors for malicious or unauthorized behavior to help protect cloud accounts and workloads. A secure VPN (Virtual Private Network) connection is used for remote external access to the production network by authorized PROGRESS LEARNING employees. The use of client-based VPN connections is restricted to authorized employees through usernames and passwords. Encryption is utilized. Multifactor authentication is enabled.	Inspected the cloud provider configuration and literature to determine that PROGRESS LEARNING utilizes the IDS security services of the cloud provider to provide managed threat detection that continuously monitors for malicious or unauthorized behavior to help protect cloud accounts and workloads. Inquired of management to determine that a secure VPN connection is used for remote external access to the production network by authorized PROGRESS LEARNING employees. Inspected firewall or Active Directory configurations to determine that the use of client-based VPN connections is restricted to authorized employees through usernames and passwords. Inspected the VPN encryption certificates to determine that encryption is utilized. Observed a VPN connection to determine that multifactor authentication is enabled.	No exceptions noted. No exceptions noted. No exceptions noted. No exceptions noted. No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC6.0 - COMMON CRITERIA RELATED TO LOGICAL AND PHYSICAL ACCESS CONTROLS

The criteria relevant to how an entity (i) restricts logical and physical access, (ii) provides and removes that access, and (iii) prevents unauthorized access.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Employees must sign a confidentiality and non-disclosure agreement to not disclose proprietary or confidential information, including client information, to unauthorized parties.	Inspected completed acknowledgment forms for a sample of employees hired during the review period to determine that the employees signed a confidentiality agreement to not disclose proprietary or confidential information, including client information, to unauthorized parties.	No exceptions noted.
		Production systems backup data is encrypted at rest.	Inspected the backup configurations to determine that the backups are encrypted at rest.	No exceptions noted.
		Access to data is restricted to authorized applications through access control software. Access rules are created and maintained by information security personnel during the application development process.	Inspected access control software to determine that access to data is restricted to authorized applications through access control software.	No exceptions noted.
			Inquired of management to determine that access rules are created and maintained by information security personnel during the application development process.	No exceptions noted.
		Management has a data classification methodology to identify and classify sensitive data in the production environment.	Inspected data classification policy to determine that management has a data classification methodology to identify and classify sensitive data.	No exceptions noted.
		Encryption methods are in place and utilized for sensitive production data storage.	Inspected encryption configurations to determine that encryption methods are in place and utilized	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC6.0 - COMMON CRITERIA RELATED TO LOGICAL AND PHYSICAL ACCESS CONTROLS

The criteria relevant to how an entity (i) restricts logical and physical access, (ii) provides and removes that access, and (iii) prevents unauthorized access.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC6.2	Prior to issuing system credentials and granting system access, the entity registers and authorizes new internal and external users whose access is administered by the entity. For those users whose access is administered by the entity, user system credentials are removed when user access is no longer authorized.	Application security restricts output to approved roles or user IDs.	for sensitive production data storage. Inspected application security to determine that application security restricts output to approved roles or user IDs.	No exceptions noted.
		Policies and procedures are in place to add new users, modify the access levels of existing users, and remove users who no longer need access.	Inspected the policies and procedures to determine that new user access, modification, and removal policies are in place.	No exceptions noted.
		Management utilizes a new hire checklist to ensure that specific elements of the hiring process are consistently executed. A copy of the checklist is kept in the employee file.	Inspected a sample of new hire checklists used for employees hired during the review period to determine that management utilizes a new hire checklist for the employees	No exceptions noted.
			Inquired of management to determine that the new hire checklists are retained in the employee files.	No exceptions noted.
		Management revokes corporate network and production server connection privileges assigned to terminated employees as a component of the employee termination process.	Inspected a sample of domain user listings to determine that management revoked corporate network and production server access privileges assigned to terminated employees as a	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC6.0 - COMMON CRITERIA RELATED TO LOGICAL AND PHYSICAL ACCESS CONTROLS

The criteria relevant to how an entity (i) restricts logical and physical access, (ii) provides and removes that access, and (iii) prevents unauthorized access.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Management utilizes a termination checklist to ensure that specific elements of the termination process are consistently executed. A copy of the checklist is kept in the employee file.	component of the employee termination process. Inspected a sample of termination checklists for any employees terminated during the review period to determine that management utilizes a termination checklist to ensure that specific elements of the termination process are consistently executed	No exceptions noted.
		User access reviews are performed monthly and documented to verify that accounts are assigned to authorized personnel.	Inquired of management to determine that the termination checklists are retained in the employee files. Inspected a sample of documented monthly user access reviews performed during the review period to determine that user access reviews were performed monthly and documented to verify that accounts are assigned to authorized personnel.	No exceptions noted.
		Administrative access reviews are performed annually and documented to verify that administrative access is assigned to authorized personnel only.	Inspected a sample of documented annual administrative access reviews performed during the review period to determine that administrative access reviews were performed annually and documented to verify that administrative access is assigned to authorized personnel only.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC6.0 - COMMON CRITERIA RELATED TO LOGICAL AND PHYSICAL ACCESS CONTROLS

The criteria relevant to how an entity (i) restricts logical and physical access, (ii) provides and removes that access, and (iii) prevents unauthorized access.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC6.3	The entity authorizes, modifies, or removes access to data, software, functions, and other protected information assets based on roles, responsibilities, or the system design and changes, giving consideration to the concepts of least privilege and segregation of duties, to meet the entity's objectives.	Each customer is assigned a designated administrator during the onboarding process with authority to create or modify user access to the hosted user application for their organization.	Inspected the hosted user application configuration to determine that each customer is assigned a designated administrator with authority to create or modify user access for their organization.	No exceptions noted.
		Policies and procedures are in place to add new users, modify the access levels of existing users, and remove users who no longer need access.	Inspected the policies and procedures to determine that new user access, modification, and removal policies are in place.	No exceptions noted.
		Management revokes corporate network and production server connection privileges assigned to terminated employees as a component of the employee termination process.	Inspected a sample of domain user listings to determine that management revoked corporate network and production server access privileges assigned to terminated employees as a component of the employee termination process.	No exceptions noted.
		User access reviews are performed monthly and documented to verify that accounts are assigned to authorized personnel.	Inspected a sample of documented monthly user access reviews performed during the review period to determine that user access reviews were performed monthly and documented to verify that accounts are assigned to authorized personnel.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC6.0 - COMMON CRITERIA RELATED TO LOGICAL AND PHYSICAL ACCESS CONTROLS

The criteria relevant to how an entity (i) restricts logical and physical access, (ii) provides and removes that access, and (iii) prevents unauthorized access.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Administrative access reviews are performed annually and documented to verify that administrative access is assigned to authorized personnel only.	Inspected a sample of documented annual administrative access reviews performed during the review period to determine that administrative access reviews were performed annually and documented to verify that administrative access is assigned to authorized personnel only.	No exceptions noted.
		Management has segregated specific duties within the production environment for administering critical areas such as: • Network administration • Systems (including Active Directory) administration • Database administration • Development.	Inspected access rights listing to determine that management has segregated specific duties within the production environment for administering critical areas.	No exceptions noted.
		Users are assigned to pre-defined roles and access rights within all PROGRESS LEARNING systems: • Access to sensitive production server directories and files is restricted based on job responsibilities. • Users are granted variable access rights according to a rights authorization methodology. • Access to systems is granted on a "least privilege" basis, with employees acquiring access only to those systems necessary to perform their job functions.	Inquired of management to determine that users are assigned to pre-defined roles and access rights within all PROGRESS LEARNING production systems and that variable rights are assigned based on job responsibilities and least privilege.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC6.0 - COMMON CRITERIA RELATED TO LOGICAL AND PHYSICAL ACCESS CONTROLS

The criteria relevant to how an entity (i) restricts logical and physical access, (ii) provides and removes that access, and (iii) prevents unauthorized access.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
			Inspected the access rights listing to determine that users are assigned to variable, pre-defined roles and access rights within all PROGRESS LEARNING production systems.	No exceptions noted.
		Production server users are granted variable access rights according to a rights authorization methodology.	Inspected the production server access rights to determine that production server users are granted variable access rights according to a rights authorization methodology.	No exceptions noted.
		Each customer is assigned a designated administrator during the onboarding process with authority to create or modify user access to the hosted user application for their organization.	Inspected the hosted user application configuration to determine that each customer is assigned a designated administrator with authority to create or modify user access for their organization.	No exceptions noted.
		Security groups are utilized to manage access privileges within the hosted user application.	Inspected a sample of security groups and access privileges to determine that security groups were utilized to manage access privileges within the hosted user application.	No exceptions noted.
		PROGRESS LEARNING utilizes the services and controls of Amazon Web Services (AWS) for housing critical production computer servers, applications, and networking equipment.	Inspected the AWS control panel to determine that PROGRESS LEARNING utilizes the services and controls of AWS for housing critical production computer servers, applications, and networking equipment.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC6.0 - COMMON CRITERIA RELATED TO LOGICAL AND PHYSICAL ACCESS CONTROLS

The criteria relevant to how an entity (i) restricts logical and physical access, (ii) provides and removes that access, and (iii) prevents unauthorized access.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC6.4	The entity restricts physical access to facilities and protected information assets (for example, data center facilities, back-up media storage, and other sensitive locations) to authorized personnel to meet the entity's objectives.	The third-party data center has physical access controls in place to <i>restrict access</i> to authorized personnel only.	Inspected the most recent SOC audit report for the third-party data center to determine that the third-party data center has physical access controls in place to <i>restrict access</i> to authorized personnel only.	No exceptions noted.
		PROGRESS LEARNING management reviews the SOC audit report of the third-party data center annually and documents the results of the review of the SOC audit report in a memo.	Inspected management's memo to determine that PROGRESS LEARNING management documents the results of the review of the SOC report in a memo.	No exceptions noted.
		PROGRESS LEARNING utilizes the services and controls of Amazon Web Services (AWS) for housing critical production computer servers, applications, and networking equipment.	Inspected the AWS control panel to determine that PROGRESS LEARNING utilizes the services and controls of AWS for housing critical production computer servers, applications, and networking equipment.	No exceptions noted.
		The third-party data center has physical access controls in place to <i>restrict access</i> to authorized personnel only.	Inspected the most recent SOC audit report for the third-party data center to determine that the third-party data center has physical access controls in place to <i>restrict access</i> to authorized personnel only.	No exceptions noted.
		PROGRESS LEARNING management reviews the SOC audit report of the third-party data center annually and documents the results of the review of the SOC audit report in a memo.	Inspected management's memo to determine that PROGRESS LEARNING management documents the results of the review of the SOC report in a memo.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC6.0 - COMMON CRITERIA RELATED TO LOGICAL AND PHYSICAL ACCESS CONTROLS

The criteria relevant to how an entity (i) restricts logical and physical access, (ii) provides and removes that access, and (iii) prevents unauthorized access.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC6.5	The entity discontinues logical and physical protections over physical assets only after the ability to read or recover data and software from those assets has been diminished and is no longer required to meet the entity's objectives.	Policies and procedures are in place for classifying data based on its criticality and sensitivity and that classification is one of many factors used to define protection requirements, access rights and restrictions, and retention and destruction requirements.	Inspected the policies and procedures to determine that data classification, protection requirements, access rights, access restrictions, and retention and destruction policies were established.	No exceptions noted.
		Documented policies and procedures are in place to guide personnel regarding disposal of confidential client information.	Inspected the disposal policies and procedures to determine that documented policies and procedures were in place to guide personnel regarding the disposal of confidential client information.	No exceptions noted.
		The organization has documented policies and procedures governing secure disposal of media and equipment.	Inspected the policies and procedures to determine that the organization has requirements for equipment and media destruction.	No exceptions noted.
		Sensitive information that is no longer needed is destroyed to prevent unauthorized access to sensitive data. This includes, but is not limited to, the following: • All paper containing sensitive information that is no longer needed is shredded. • Electronic media and equipment are sanitized before re-use or physically destroyed before disposal.	Inquired of management about sensitive information disposal practices to determine that: • All paper containing sensitive information that is no longer needed is shredded. • Electronic media and equipment are sanitized before re-use or physically destroyed before disposal.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC6.0 - COMMON CRITERIA RELATED TO LOGICAL AND PHYSICAL ACCESS CONTROLS

The criteria relevant to how an entity (i) restricts logical and physical access, (ii) provides and removes that access, and (iii) prevents unauthorized access.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC6.6	The entity implements logical access security measures to protect against threats from sources outside its system boundaries.	PROGRESS LEARNING utilizes the services and controls of Amazon Web Services (AWS) for housing critical production computer servers, applications, and networking equipment.	Inspected the AWS control panel to determine that PROGRESS LEARNING utilizes the services and controls of AWS for housing critical production computer servers, applications, and networking equipment.	No exceptions noted.
		The third-party data center has physical access controls in place to <i>remove access</i> when no longer required.	Inspected the most recent SOC audit report for the third-party data center to determine that the third-party data center has physical access controls in place to <i>remove access</i> when no longer required.	No exceptions noted.
		PROGRESS LEARNING management reviews the SOC audit report of the third-party data center annually and documents the results of the review of the SOC audit report in a memo.	Inspected management's memo to determine that PROGRESS LEARNING management documents the results of the review of the SOC report in a memo.	No exceptions noted.
		Management revokes corporate network and production server connection privileges assigned to terminated employees as a component of the employee termination process.	Inspected a sample of domain user listings to determine that management revoked corporate network and production server access privileges assigned to terminated employees as a component of the employee termination process.	No exceptions noted.
		Policies and procedures are in place to guide personnel regarding sharing information with third parties.	Inspected the policies and procedures and the service level agreements to determine that the entity's policies included procedures to guide personnel regarding sharing information with third parties.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC6.0 - COMMON CRITERIA RELATED TO LOGICAL AND PHYSICAL ACCESS CONTROLS

The criteria relevant to how an entity (i) restricts logical and physical access, (ii) provides and removes that access, and (iii) prevents unauthorized access.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Procedures have been implemented to provide that confidential information is disclosed to third parties only in accordance with the entity's defined confidentiality and related security policies.	Inspected confidentiality policies and procedures related to disclosure to third parties to determine that confidential information is disclosed to third parties only in accordance with the entity's defined confidentiality and related security policies.	No exceptions noted.
		The ability to modify the cloud provider security services configurations or rule sets is restricted based on job responsibility.	Inspected system access documentation and cloud provider access rights to determine that the ability to modify the cloud provider security services configurations or rule sets is restricted based on job responsibility.	No exceptions noted.
		Firewall systems are in place to handle data flow between external parties and cloud hosted networks. External traffic originating from the Internet must pass through a firewall system to communicate with production servers. No direct conversations originating from the Internet pass directly through to the cloud private networks.	Inspected the firewall system rule sets to determine that firewall systems are in place to handle data flow between external parties and the cloud hosted networks.	No exceptions noted.
		PROGRESS LEARNING utilizes cloud firewall services at several levels: • Web Application Firewall (WAF) • Private Networks • Instance-level access control lists (ACLs) • Load Balancers.	Inquired of management to determine that PROGRESS LEARNING utilizes cloud firewall services at several levels as indicated.	No exceptions noted.
		Load balancers and private networks are utilized to isolate production instances from public access.	Inquired of management to determine that load balancers and private networks are utilized to	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC6.0 - COMMON CRITERIA RELATED TO LOGICAL AND PHYSICAL ACCESS CONTROLS

The criteria relevant to how an entity (i) restricts logical and physical access, (ii) provides and removes that access, and (iii) prevents unauthorized access.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
			isolate production instances from public access.	
			Inspected cloud provider's configuration to determine that load balancers and private networks are utilized to isolate internal production instances from public access.	No exceptions noted.
		A Web Application Firewall (WAF) is utilized to protect web applications from common web exploits that could affect application availability, compromise security, or consume excessive resources.	Inspected cloud provider's configuration to determine that a Web Application Firewall is utilized to protect web applications from common web exploits that could affect application availability, compromise security, or consume excessive resources.	No exceptions noted.
		Instance-level access control lists are utilized to control both inbound and outbound traffic to cloud hosted virtual instances and employ the following features: • Stateful packet inspection. • Ports are configured to allow only specific types of traffic between certain destinations. All unused ports are blocked. • Configured to deny all traffic that is not specifically authorized in the rule set.	Inspected instance-level access control list configurations and cloud provider literature to determine that instance-level access control lists are utilized to filter internet traffic based on content and destination site address and that stateful packet inspection is utilized.	No exceptions noted.
			Inspected the instance-level access control list configuration to determine that instance-level access control lists are configured to allow only specific types of traffic between certain destinations and that unused ports are disabled.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC6.0 - COMMON CRITERIA RELATED TO LOGICAL AND PHYSICAL ACCESS CONTROLS

The criteria relevant to how an entity (i) restricts logical and physical access, (ii) provides and removes that access, and (iii) prevents unauthorized access.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
			Inspected cloud provider literature to determine that instance-level access control lists deny traffic that is not specifically authorized in the rule set.	No exceptions noted.
		Instance-level access control lists on cloud hosted virtual instances are configured with whitelists to trust IP addresses or IP ranges. The whitelists are utilized for limiting and controlling access only to trusted users to certain services or applications.	Inspected the instance-level access control list configurations to determine that instance-level access control lists are configured with whitelists to limit and control access only to trusted users to certain services or applications.	No exceptions noted.
		PROGRESS LEARNING utilizes the security services of the cloud provider to absorb DoS/DDoS attacks and to help protect public facing applications from common exploits that could affect application availability, compromise security, or consume excessive resources.	Inquired of management to determine that PROGRESS LEARNING utilizes the security services of the cloud provider to absorb DoS/DDoS attacks and to help protect public facing applications from common exploits that could affect application availability, compromise security, or consume excessive resources.	No exceptions noted.
			Inspected the cloud provider configuration and literature to determine that PROGRESS LEARNING utilizes the security services of the cloud provider to absorb DoS/DDoS attacks and to help protect public facing applications from common exploits that could affect application availability, compromise security, or consume excessive resources.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC6.0 - COMMON CRITERIA RELATED TO LOGICAL AND PHYSICAL ACCESS CONTROLS

The criteria relevant to how an entity (i) restricts logical and physical access, (ii) provides and removes that access, and (iii) prevents unauthorized access.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		PROGRESS LEARNING utilizes the Intrusion Detection System (IDS) security services of the cloud provider to provide managed threat detection that continuously monitors for malicious or unauthorized behavior to help protect cloud accounts and workloads. Cloud provider security services are configured to log all modifications to security services configurations or rule set changes, and logs are available for ad hoc review by security personnel. A secure VPN (Virtual Private Network) connection is used for remote external access to the production network by authorized PROGRESS LEARNING employees. The use of client-based VPN connections is restricted to authorized employees through usernames and passwords. Encryption is utilized. Multifactor authentication is enabled.	Inspected the cloud provider configuration and literature to determine that PROGRESS LEARNING utilizes the IDS security services of the cloud provider to provide managed threat detection that continuously monitors for malicious or unauthorized behavior to help protect cloud accounts and workloads. Inquired of management to determine that all modifications to the cloud provider security services configurations or rule sets are logged and available for ad hoc review by security personnel. Inspected a sample of logs of modifications to the security service configurations or rule sets to determine that logs are available for ad hoc review by security personnel. Inquired of management to determine that a secure VPN connection is used for remote external access to the production network by authorized PROGRESS LEARNING employees. Inspected firewall or Active Directory configurations to determine that the use of client-based VPN connections is	No exceptions noted. No exceptions noted. No exceptions noted. No exceptions noted. No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC6.0 - COMMON CRITERIA RELATED TO LOGICAL AND PHYSICAL ACCESS CONTROLS

The criteria relevant to how an entity (i) restricts logical and physical access, (ii) provides and removes that access, and (iii) prevents unauthorized access.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
			restricted to authorized employees through usernames and passwords.	
			Inspected the VPN encryption certificates to determine that encryption is utilized.	No exceptions noted.
			Observed a VPN connection to determine that multifactor authentication is enabled.	No exceptions noted.
		The production network is logically and physically segregated from the internal corporate network.	Inspected a network diagram to determine that the production network was logically and physically segregated from the internal corporate network.	No exceptions noted.
		Demilitarized Zones (DMZs) are utilized within the PROGRESS LEARNING network, separating the production environment from internal functions.	Inspected the network diagram to determine that Demilitarized Zones (DMZs) are utilized within the network environment.	No exceptions noted.
		Application security restricts output to approved roles or user IDs.	Inspected application security to determine that application security restricts output to approved roles or user IDs.	No exceptions noted.
		Communication sessions between PROGRESS LEARNING's servers/applications and external parties are secured using various encryption methods when applicable.	Inquired of management to determine that communication sessions between PROGRESS LEARNING servers and applications and certain external parties are secured using encryption methods when applicable.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC6.0 - COMMON CRITERIA RELATED TO LOGICAL AND PHYSICAL ACCESS CONTROLS

The criteria relevant to how an entity (i) restricts logical and physical access, (ii) provides and removes that access, and (iii) prevents unauthorized access.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC6.7	The entity restricts the transmission, movement, and removal of information to authorized internal and external users and processes, and protects it during transmission, movement, or removal to meet the entity's objectives.	Logical access to stored data is restricted to the application, database administrators, and on a need-to-know basis.	Inquired of management to determine that logical access to stored data is restricted to the application, database administrators, and on a need-to-know basis.	No exceptions noted.
			Inspected the access rights listing to determine that logical access to stored data is restricted to the application, database administrators, and on a need-to-know basis.	No exceptions noted.
		Employees must sign a confidentiality and non-disclosure agreement to not disclose proprietary or confidential information, including client information, to unauthorized parties.	Inspected completed acknowledgment forms for a sample of employees hired during the review period to determine that the employees signed a confidentiality agreement to not disclose proprietary or confidential information, including client information, to unauthorized parties.	No exceptions noted.
		Policies and procedures are in place to guide personnel regarding sharing information with third parties.	Inspected the policies and procedures and the service level agreements to determine that the entity's policies included procedures to guide personnel regarding sharing information with third parties.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC6.0 - COMMON CRITERIA RELATED TO LOGICAL AND PHYSICAL ACCESS CONTROLS

The criteria relevant to how an entity (i) restricts logical and physical access, (ii) provides and removes that access, and (iii) prevents unauthorized access.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		The use of client-based VPN connections is restricted to authorized employees through usernames and passwords. Encryption is utilized. Multifactor authentication is enabled.	Inspected firewall or Active Directory configurations to determine that the use of client-based VPN connections is restricted to authorized employees through usernames and passwords.	No exceptions noted.
			Inspected the VPN encryption certificates to determine that encryption is utilized.	No exceptions noted.
			Observed a VPN connection to determine that multifactor authentication is enabled.	No exceptions noted.
		Transmission of digital output beyond the boundary of the system occurs through the use of authorized software supporting the advanced encryption standard (AES).	Inquired of management to determine that transmissions of digital output beyond the boundary of the system occurs through the use of authorized software supporting the advanced encryption standard (AES).	No exceptions noted.
		Communication sessions between PROGRESS LEARNING's servers/applications and external parties are secured using various encryption methods when applicable.	Inquired of management to determine that communication sessions between PROGRESS LEARNING servers and applications and certain external parties are secured using encryption methods when applicable.	No exceptions noted.
		File transfer sessions that utilize production server applications are secured through the use of encryption.	Inspected the encryption configuration to determine that communication sessions utilizing production server applications is	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC6.0 - COMMON CRITERIA RELATED TO LOGICAL AND PHYSICAL ACCESS CONTROLS

The criteria relevant to how an entity (i) restricts logical and physical access, (ii) provides and removes that access, and (iii) prevents unauthorized access.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC6.8	The entity implements controls to prevent or detect and act upon the introduction of unauthorized or malicious software to meet the entity's objectives.	Transaction processing performed on web-based applications is secured through the use of the Transport Layer Security (TLS) encryption protocol over HTTPS connections. - This includes the use of the website file upload page. - Traffic directed to HTTP connections for this are redirected to HTTPS connections.	secured through the use of encryption. Inspected the web application TLS certificates to determine that transaction processing performed on web-based applications is secured through the use of the Transport Layer Security (TLS) protocol and that licensing is current.	No exceptions noted.
		Security groups are utilized to manage access privileges within the hosted user application.	Observed a connection to HTTP to determine that it is automatically redirected to an HTTPS connection. Inspected a sample of security groups and access privileges to determine that security groups were utilized to manage access privileges within the hosted user application.	No exceptions noted. No exceptions noted.
		Policies and procedures are in place to guide personnel regarding identifying and mitigating security breaches and other incidents.	Inspected the policies and procedures to determine that the entity's policies included procedures regarding identifying and mitigating system security breaches and other incidents.	No exceptions noted.
		Only authorized system administrators are able to install software on system devices.	Inquired of management to determine that only authorized system administrators are able to install software on system devices.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC6.0 - COMMON CRITERIA RELATED TO LOGICAL AND PHYSICAL ACCESS CONTROLS

The criteria relevant to how an entity (i) restricts logical and physical access, (ii) provides and removes that access, and (iii) prevents unauthorized access.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Antivirus software is installed on all PROGRESS LEARNING servers (endpoint protection).	Inquired of management to determine that third-party antivirus software is installed on all PROGRESS LEARNING servers.	No exceptions noted.
			Inspected antivirus software installed on sample of PROGRESS LEARNING servers to determine that antivirus software is installed on all PROGRESS LEARNING servers.	No exceptions noted.
		Antivirus applications are managed at the local server level. - Definition updates are performed on a periodic basis. - Real-time scans are enabled.	Inspected a sample of servers managed at the local level to determine that antivirus definition updates are performed on a periodic basis and that system scans are performed on a weekly basis.	No exceptions noted.
		Third-party antivirus and spam filtering is utilized by PROGRESS LEARNING to filter incoming email for viruses and spam.	Inspected the third-party antivirus and spam filtering configuration to determine that third-party antivirus and spam filtering is utilized by PROGRESS LEARNING to filter incoming email for viruses and spam.	No exceptions noted.
		An automated methodology is utilized for managing workstation updates using a dedicated update service.	Inspected update configurations to determine that an automated methodology is utilized to roll out workstation updates.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC6.0 - COMMON CRITERIA RELATED TO LOGICAL AND PHYSICAL ACCESS CONTROLS

The criteria relevant to how an entity (i) restricts logical and physical access, (ii) provides and removes that access, and (iii) prevents unauthorized access.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Third-party antivirus software is installed on all PROGRESS LEARNING workstations and laptops (endpoint protection). Antivirus definition updates are performed by the antivirus application on a regular basis.	Inspected antivirus software installed on sample of PROGRESS LEARNING workstations and laptops to determine that antivirus software is installed on all PROGRESS LEARNING workstations and laptops.	No exceptions noted.
			Inspected AV software configuration to determine that antivirus definition updates are performed on a regular basis.	No exceptions noted.
		A management-approved methodology is utilized to monitor operating system patch releases, distribute patches to relevant devices and apply the patches to the device.	Inquired of management to determine that a methodology is utilized to monitor operating system patch releases, distribute patches to relevant devices and apply the patches to the device.	No exceptions noted.
			Inspected a sample of servers and workstations to determine that a management-approved methodology is utilized to monitor operating system patch releases, distribute patches to relevant devices and apply the patches to the device.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY**CC6.0 - COMMON CRITERIA RELATED TO LOGICAL AND PHYSICAL ACCESS CONTROLS**

The criteria relevant to how an entity (i) restricts logical and physical access, (ii) provides and removes that access, and (iii) prevents unauthorized access.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		PROGRESS LEARNING IT personnel utilize security issue monitoring services to keep abreast of recent critical issues, attacks and vulnerabilities that must be addressed immediately.	Inspected a sample of informational service communications to determine that IT personnel utilize security issue monitoring services. Inquired of management to determine that PROGRESS LEARNING IT personnel utilize security issue monitoring services to keep abreast of recent critical issues, attacks and vulnerabilities that must be addressed immediately.	No exceptions noted. No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC7.0 - COMMON CRITERIA RELATED TO SYSTEM OPERATIONS

The criteria relevant to how an entity (i) manages the operation of system(s) and (ii) detects and mitigates processing deviations, including logical and physical security deviations.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC7.1	To meet its objectives, the entity uses detection and monitoring procedures to identify (1) changes to configurations that result in the introduction of new vulnerabilities, and (2) susceptibilities to newly discovered vulnerabilities.	Third-party enterprise monitoring applications are used to monitor system downtime and operations issues to help ensure that system downtime and performance does not exceed predefined levels. This includes monitoring of both critical network and server hardware, as well as processes and services: - System uptime and downtime - Critical performance metrics (CPU utilization, storage, etc.). Problems with critical systems are remediated as necessary.	Inspected the enterprise monitoring applications to determine that third-party enterprise monitoring applications are used to monitor performance criteria for critical server and network equipment.	No exceptions noted.
			Inspected the metrics tracking reports to determine that system downtime and operations issues were monitored.	No exceptions noted.
			Inspected a sample of Slack alerts to determine that problems with critical systems are remediated as necessary	No exceptions noted.
		The enterprise monitoring application is configured to send alert notifications to operations personnel when predefined metrics are exceeded on monitored network devices. Alerts are communicated via SMS text or email to appropriate support personnel.	Inspected the enterprise monitoring application configuration screens to determine that performance thresholds are set, and alerts are communicated if pre-determined metrics are reached.	No exceptions noted.
		Management utilizes vulnerability assessment tools (VAT) to help determine vulnerability risks and evaluates and takes action on issues identified in the report.	Inspected vulnerability assessment tools, configurations and test reports generated to determine that management utilizes vulnerability assessment tools to help determine vulnerability risks.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC7.0 - COMMON CRITERIA RELATED TO SYSTEM OPERATIONS

The criteria relevant to how an entity (i) manages the operation of system(s) and (ii) detects and mitigates processing deviations, including logical and physical security deviations.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC7.2	The entity monitors system components and the operation of those components for anomalies that are indicative of malicious acts, natural disasters, and errors affecting the entity's ability to meet its objectives; anomalies are analyzed to determine whether they represent security events.	A management-approved methodology is utilized to monitor operating system patch releases, distribute patches to relevant devices and apply the patches to the device.	Inspected a sample of closed tickets remediating issues in the most recent report to determine that management evaluates and takes action on issues identified in the report.	No exceptions noted.
			Inquired of management to determine that a methodology is utilized to monitor operating system patch releases, distribute patches to relevant devices and apply the patches to the device.	No exceptions noted.
			Inspected a sample of servers and workstations to determine that a management-approved methodology is utilized to monitor operating system patch releases, distribute patches to relevant devices and apply the patches to the device.	No exceptions noted.
			Inspected a sample of informational service communications to determine that IT personnel utilize security issue monitoring services.	No exceptions noted.
			Inquired of management to determine that PROGRESS LEARNING IT personnel utilize security issue monitoring services	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC7.0 - COMMON CRITERIA RELATED TO SYSTEM OPERATIONS

The criteria relevant to how an entity (i) manages the operation of system(s) and (ii) detects and mitigates processing deviations, including logical and physical security deviations.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
			to keep abreast of recent critical issues, attacks and vulnerabilities that must be addressed immediately.	
		Cloud provider security services are configured to log all modifications to security services configurations or rule set changes, and logs are available for ad hoc review by security personnel.	Inquired of management to determine that all modifications to the cloud provider security services configurations or rule sets are logged and available for ad hoc review by security personnel.	No exceptions noted.
			Inspected a sample of logs of modifications to the security service configurations or rule sets to determine that logs are available for ad hoc review by security personnel.	No exceptions noted.
		Management periodically performs internal security assessments, including reviews of server logs and other critical items.	Inspected results from internal security assessments performed during the review period to determine that management periodically performs internal security assessments.	No exceptions noted.
		PROGRESS LEARNING periodically contracts with a third-party network security company to conduct external network penetration tests and vulnerability assessments. A report is generated and reviewed by management, and tickets are generated for any necessary remedial action.	Inquired of management to determine that PROGRESS LEARNING periodically contracts with a third-party network security company to conduct external network penetration tests and vulnerability assessments and that management reviews any reports and generates tickets for any necessary remedial action.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC7.0 - COMMON CRITERIA RELATED TO SYSTEM OPERATIONS

The criteria relevant to how an entity (i) manages the operation of system(s) and (ii) detects and mitigates processing deviations, including logical and physical security deviations.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
			Inspected report from a sample of external network penetration tests and vulnerability assessments during the review period to determine that a report is generated and reviewed by management.	No exceptions noted.
			Inspected a sample of tickets or other internal communications during the review period to determine tickets are generated for any necessary remedial action.	No exceptions noted.
		PROGRESS LEARNING has implemented a backup policy, and backups of production systems and data are completed in a timely manner. The retention period for backup data has been defined by management.	Inquired of management to determine that PROGRESS LEARNING has implemented a backup policy, and that backups of production systems and data are completed in a timely manner.	No exceptions noted.
			Inspected the backup policy, backup configurations, and a sample of backup logs to determine that PROGRESS LEARNING has implemented a backup policy, and that backups of production systems and data are completed in a timely manner.	No exceptions noted.
			Inspected the backup policy and backup configurations to determine that the retention period for backup data has been defined by management.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC7.0 - COMMON CRITERIA RELATED TO SYSTEM OPERATIONS

The criteria relevant to how an entity (i) manages the operation of system(s) and (ii) detects and mitigates processing deviations, including logical and physical security deviations.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC7.3	The entity evaluates security events to determine whether they could or have resulted in a failure of the entity to meet its objectives (security incidents) and, if so, takes actions to prevent or address such failures.	Logs track the backup events, and IT staff check the backup status daily and investigate any failures and remediate as necessary.	Inspected a sample of backup event logs to determine that logs track the backup events.	No exceptions noted.
			Inquired of management to determine that IT staff check the backup status daily and failures are investigated and remediated.	No exceptions noted.
		Quarterly restores of backups are performed to verify backup integrity and employee readiness.	Inspected a sample of quarterly restores to determine that quarterly restores of backups are performed to verify backup integrity and employee readiness.	No exceptions noted.
		Policies and procedures are in place to guide personnel regarding identifying and mitigating security breaches and other incidents.	Inspected the policies and procedures to determine that the entity's policies included procedures regarding identifying and mitigating system security and related security breaches and other incidents.	No exceptions noted.
		Policies and procedures are in place to guide personnel regarding addressing how complaints and requests relating to security issues are resolved.	Inspected the policies and procedures to determine that the entity's policies included procedures regarding resolution of complaints and requests relating to system security and related issues.	No exceptions noted.
		An Incident Response plan is in place to ensure appropriate response to outages or security incidents in an organized and timely manner.	Inspected the incident response plan to determine that a plan is in place to ensure appropriate response to outages or security incidents.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC7.0 - COMMON CRITERIA RELATED TO SYSTEM OPERATIONS

The criteria relevant to how an entity (i) manages the operation of system(s) and (ii) detects and mitigates processing deviations, including logical and physical security deviations.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		A ticketing system is utilized to manage systems infrastructure issues and changes. Tickets are assigned to support personnel based on the nature of the ticket.	Inspected logs from the ticketing system showing closed tickets to determine that a ticketing system was utilized to manage systems infrastructure issues and that tickets were assigned to support personnel based on the nature of the ticket.	No exceptions noted.
		Helpdesk calls are entered into the ticketing system and call tracking utility and given a ticket number. • A priority level is assigned in accordance with company policy. • All issues that cannot be addressed within appropriate time intervals are escalated to management to assure timely resolution. • Call volume and open tickets are reviewed periodically by helpdesk staff.	Inquired of management to determine that helpdesk calls are entered into the call tracking utility and given a ticket number, a priority level is assigned in accordance with company policy, and all issues that cannot be addressed within appropriate time intervals are escalated to management to assure timely resolution.	No exceptions noted.
			Inspected the ticketing system to determine that a priority level is assigned in accordance with company policy, all issues that cannot be addressed within appropriate time intervals are escalated to management to assure timely resolution, and call volume and open tickets are reviewed periodically by helpdesk staff.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY
CC7.0 - COMMON CRITERIA RELATED TO SYSTEM OPERATIONS

The criteria relevant to how an entity (i) manages the operation of system(s) and (ii) detects and mitigates processing deviations, including logical and physical security deviations.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC7.4	The entity responds to identified security incidents by executing a defined incident response program to understand, contain, remediate, and communicate security incidents, as appropriate.	Documented change requests are completed for bug fixes, enhancements and new development.	Inspected a sample of product changes from the review period for entries in the tracking system to determine that requests were completed for bug fixes, enhancements and new development.	No exceptions noted.
		Policies and procedures are in place to guide personnel regarding identifying and mitigating security breaches and other incidents.	Inspected the policies and procedures to determine that the entity's policies included procedures regarding identifying and mitigating system security and related security breaches and other incidents.	No exceptions noted.
		Policies and procedures are in place to guide personnel regarding addressing how complaints and requests relating to security issues are resolved.	Inspected the policies and procedures to determine that the entity's policies included procedures regarding resolution of complaints and requests relating to system security and related issues.	No exceptions noted.
		An Incident Response plan is in place to ensure appropriate response to outages or security incidents in an organized and timely manner.	Inspected the incident response plan to determine that a plan is in place to ensure appropriate response to outages or security incidents.	No exceptions noted.
CC7.5	The entity identifies, develops, and implements activities to recover from identified security incidents.	Policies and procedures are in place to guide personnel regarding identifying and mitigating security breaches and other incidents.	Inspected the policies and procedures to determine that the entity's policies included procedures regarding identifying and mitigating system security and related security breaches and other incidents.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC7.0 - COMMON CRITERIA RELATED TO SYSTEM OPERATIONS

The criteria relevant to how an entity (i) manages the operation of system(s) and (ii) detects and mitigates processing deviations, including logical and physical security deviations.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Policies and procedures are in place to guide personnel regarding addressing how complaints and requests relating to security issues are resolved. An Incident Response plan is in place to ensure appropriate response to outages or security incidents in an organized and timely manner. A ticketing system is utilized to manage systems infrastructure issues and changes. Tickets are assigned to support personnel based on the nature of the ticket. Helpdesk calls are entered into the ticketing system and call tracking utility and given a ticket number. • A priority level is assigned in accordance with company policy. • All issues that cannot be addressed within appropriate time intervals are escalated to management to assure timely resolution. • Call volume and open tickets are reviewed periodically by helpdesk staff.	Inspected the policies and procedures to determine that the entity's policies included procedures regarding resolution of complaints and requests relating to system security and related issues. Inspected the incident response plan to determine that a plan is in place to ensure appropriate response to outages or security incidents. Inspected logs from the ticketing system showing closed tickets to determine that a ticketing system was utilized to manage systems infrastructure issues and that tickets were assigned to support personnel based on the nature of the ticket. Inquired of management to determine that helpdesk calls are entered into the call tracking utility and given a ticket number, a priority level is assigned in accordance with company policy, and all issues that cannot be addressed within appropriate time intervals are escalated to management to assure timely resolution.	No exceptions noted. No exceptions noted. No exceptions noted. No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY**CC7.0 - COMMON CRITERIA RELATED TO SYSTEM OPERATIONS**

The criteria relevant to how an entity (i) manages the operation of system(s) and (ii) detects and mitigates processing deviations, including logical and physical security deviations.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Documented change requests are completed for bug fixes, enhancements and new development.	Inspected the ticketing system to determine that a priority level is assigned in accordance with company policy, all issues that cannot be addressed within appropriate time intervals are escalated to management to assure timely resolution, and call volume and open tickets are reviewed periodically by helpdesk staff. Inspected a sample of product changes from the review period for entries in the tracking system to determine that requests were completed for bug fixes, enhancements and new development.	No exceptions noted. No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC8.0 - COMMON CRITERIA RELATED TO CHANGE MANAGEMENT

The criteria relevant to how an entity (i) identifies the need for changes, (ii) makes the changes using a controlled change management process, and (iii) prevents unauthorized changes from being made.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC8.1	The entity authorizes, designs, develops or acquires, configures, documents, tests, approves, and implements changes to infrastructure, data, software, and procedures to meet its objectives.	Policies and procedures are in place to ensure that design, acquisition, implementation, configuration, modification, and management of infrastructure and software are consistent with defined system security policies to enable authorized access and to prevent unauthorized access.	Inspected relevant policies and procedures to determine that policies and procedures are in place to ensure that design, acquisition, implementation, configuration, modification, and management of infrastructure and software are consistent with defined system security policies to enable authorized access and to prevent unauthorized access.	No exceptions noted.
		Policies and procedures are in place for classifying data based on its criticality and sensitivity and that classification is one of many factors used to define protection requirements, access rights and restrictions, and retention and destruction requirements.	Inspected the policies and procedures to determine that data classification, protection requirements, access rights, access restrictions, and retention and destruction policies were established.	No exceptions noted.
		Policies and procedures are in place to assign responsibility and accountability for system changes and maintenance.	Inspected the policies and procedures to determine that the entity's policies included procedures regarding assigning responsibility and accountability for system changes and maintenance.	No exceptions noted.
		Policies and procedures are in place to ensure that change management processes are initiated when deficiencies in the design or operating effectiveness of controls are identified during system operation and monitoring.	Observed and inspected relevant policies and procedures to determine that policies and procedures are in place to ensure that change management processes are initiated when deficiencies in the design or operating effectiveness of controls	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC8.0 - COMMON CRITERIA RELATED TO CHANGE MANAGEMENT

The criteria relevant to how an entity (i) identifies the need for changes, (ii) makes the changes using a controlled change management process, and (iii) prevents unauthorized changes from being made.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Policies and procedures are in place to guide personnel regarding testing, evaluating, and authorizing system components before implementation. A software development life cycle is utilized to designate milestones that must be achieved throughout the development and testing process. Program development is performed in a distinct development environment that is physically separated from the production environment. Development takes place on developers' local machines. Version control software is utilized to maintain and control access to current and prior versions of application source code, and the associated reporting and logging functions.	are identified during system operation and monitoring. Inspected the policies and procedures related to testing, evaluating, and authorizing before implementation of components. Inspected software development life cycle documentation to determine that a software development life cycle was utilized to designate milestones that must be achieved throughout the development and testing process. Observed the location of the servers for each environment to determine that development environment is physically separated from the production environment. Inspected the checkout process from the version control software and a sample of local development machines to determine that development takes place on developers' local machines. Inspected and observed the version control software to determine that version control software is utilized to maintain and control access to current and prior versions of application code.	No exceptions noted. No exceptions noted. No exceptions noted. No exceptions noted. No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC8.0 - COMMON CRITERIA RELATED TO CHANGE MANAGEMENT

The criteria relevant to how an entity (i) identifies the need for changes, (ii) makes the changes using a controlled change management process, and (iii) prevents unauthorized changes from being made.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Access to version control software is restricted based upon job responsibilities. Access is restricted to approved positions only.	Inspected access rights listing to determine that access to version control software is restricted based upon job responsibilities, and that access is restricted to approved positions only.	No exceptions noted.
		Documented change requests are completed for bug fixes, enhancements and new development.	Inspected a sample of product changes from the review period for entries in the tracking system to determine that requests were completed for bug fixes, enhancements and new development.	No exceptions noted.
		A ticket or change management form is completed and properly approved before core changes are made to production application code.	Inspected a sample of tickets or change management forms to determine that a ticket or change management form is completed and properly approved before core changes are made to production application code.	No exceptions noted.
		Change management software is utilized to manage application changes, and the associated reporting and logging functions.	Inspected and observed the application to determine that change management software is utilized to manage application changes, and the associated reporting and logging functions.	No exceptions noted.
		Changes to source code results in the creation of a new version of the application code. If necessary, changes can be rolled back to prior versions of the application code.	Inspected a sample of versioning history to determine that changes to source code resulted in the creation of a new version of the application code.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC8.0 - COMMON CRITERIA RELATED TO CHANGE MANAGEMENT

The criteria relevant to how an entity (i) identifies the need for changes, (ii) makes the changes using a controlled change management process, and (iii) prevents unauthorized changes from being made.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Logs are utilized to maintain and record changes to manage and monitor development and maintenance activities.	Inspected a sampling of logs to determine that logs are utilized to maintain and record changes to manage and monitor development and maintenance activities.	No exceptions noted.
		The quality assurance and testing efforts are performed in a distinct test environment that is logically separated from the production environment.	Observed the location of the servers for each environment to determine that quality assurance and test environments are logically separated from the production environment.	No exceptions noted.
		Access to the quality assurance testing environment is restricted based upon job responsibilities.	Inspected access rights listing to determine that access to the quality assurance testing environment is restricted based upon job responsibilities.	No exceptions noted.
		Application testing takes place at several different phases of the development cycle: • Unit Testing during development. • QA Testing, including regression testing. • User Acceptance Testing (UAT) during staging.	Inquired of management to determine that application testing takes place at different phases of the development cycle.	No exceptions noted.
		Quality assurance personnel perform quality assurance testing for application changes and update the change request ticket history to indicate approval of the test results prior to migration to the production environment.	Inspected change request forms and internal release notices for changes promoted to production during the review period to determine that quality assurance personnel perform quality assurance testing for application changes and update the change request ticket history to indicate	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC8.0 - COMMON CRITERIA RELATED TO CHANGE MANAGEMENT

The criteria relevant to how an entity (i) identifies the need for changes, (ii) makes the changes using a controlled change management process, and (iii) prevents unauthorized changes from being made.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		User acceptance testing is performed and signed off on by stakeholders before migration to the production environment. Informal management approvals are obtained before application code changes are migrated to the production environment. New code is deployed to the production environment after business hours. Hot fixes are deployed immediately. Critical hardware infrastructure changes follow a structured change methodology, including testing of hardware changes where necessary.	approval of the test results prior to migration to the production environment. Inspected stakeholder approvals to determine that user acceptance testing is performed and signed off on by stakeholders before migration to the production environment. Inquired of management to determine that informal management approvals were obtained before application code changes were migrated to the production environment. Inquired of management to determine that new code is deployed to the production environment after business hours, while hot fixes are deployed immediately. Inspected the infrastructure change management policies and procedures to determine that critical hardware infrastructure changes follow a structured change methodology.	No exceptions noted. No exceptions noted. No exceptions noted. No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC8.0 - COMMON CRITERIA RELATED TO CHANGE MANAGEMENT

The criteria relevant to how an entity (i) identifies the need for changes, (ii) makes the changes using a controlled change management process, and (iii) prevents unauthorized changes from being made.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		A ticketing system is utilized to manage systems infrastructure issues and changes. Tickets are assigned to support personnel based on the nature of the ticket.	Inspected logs from the ticketing system showing closed tickets to determine that a ticketing system was utilized to manage systems infrastructure issues and that tickets were assigned to support personnel based on the nature of the ticket.	No exceptions noted.
		A Slack approval is obtained before core changes are made to the production systems environment.	Inspected a sample of Slack approvals to determine that Slack approvals are obtained before core changes are made to production systems environment.	No exceptions noted.
		A standard hardened template for virtualized environments is utilized for installation and maintenance of certain critical virtual machines.	Inspected the virtualization configurations to determine that a standard template is used for installation and maintenance of certain critical PROGRESS LEARNING virtual machines.	No exceptions noted.
		Critical production equipment is maintained under warranty and maintenance or Service Level Agreements (SLAs) with 3 rd party vendors.	Inspected current agreements with third-party vendors to determine that critical production equipment is maintained under warranty and maintenance or service level agreements with 3 rd party vendors.	No exceptions noted.
		A management-approved methodology is utilized to monitor operating system patch releases, distribute patches to relevant devices and apply the patches to the device.	Inquired of management to determine that a methodology is utilized to monitor operating system patch releases, distribute patches to relevant devices and apply the patches to the device.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC8.0 - COMMON CRITERIA RELATED TO CHANGE MANAGEMENT

The criteria relevant to how an entity (i) identifies the need for changes, (ii) makes the changes using a controlled change management process, and (iii) prevents unauthorized changes from being made.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
			Inspected a sample of servers and workstations to determine that a management-approved methodology is utilized to monitor operating system patch releases, distribute patches to relevant devices and apply the patches to the device.	No exceptions noted.
		Infrastructure changes, patches and upgrades to critical services are tested by the technical support department before being applied to a production server.	Inquired of management to determine that infrastructure changes, patches and upgrades to critical services are tested by the technical support department after hours before being introduced to a production server.	No exceptions noted.
			Inspected hardware update logs to determine that patches and upgrades to critical services are tested by the technical support department before being introduced to a production server.	No exceptions noted.
		Management has a data classification methodology to identify and classify sensitive data in the production environment.	Inspected data classification policy to determine that management has a data classification methodology to identify and classify sensitive data.	No exceptions noted.
		PROGRESS LEARNING utilizes the services and controls of a third-party data center for housing critical production computer servers, applications, and networking equipment. The third-party data center is responsible for the general IT controls relevant to its application development.	Inspected the most recent SOC audit report for the third-party data center to determine that the third-party data center is responsible for the general IT controls relevant to its application development.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC8.0 - COMMON CRITERIA RELATED TO CHANGE MANAGEMENT

The criteria relevant to how an entity (i) identifies the need for changes, (ii) makes the changes using a controlled change management process, and (iii) prevents unauthorized changes from being made.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		PROGRESS LEARNING utilizes the services and controls of a third-party data center for housing critical production computer servers, applications, and networking equipment. The third-party data center is responsible for the general IT controls relevant to its change management. PROGRESS LEARNING management reviews the SOC audit report of the third-party data center annually and documents the results of the review of the SOC audit report in a memo.	Inspected the most recent SOC audit report for the third-party data center to determine that the third-party data center is responsible for the general IT controls relevant to its change management. Inspected management's memo to determine that PROGRESS LEARNING management documents the results of the review of the SOC report in a memo.	No exceptions noted. No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY**CC9.0 - COMMON CRITERIA RELATED TO RISK MITIGATION**

The criteria relevant to how the entity identifies, selects and develops risk mitigation activities arising from potential business disruptions and the use of vendors and business partners.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC9.1	The entity identifies, selects, and develops risk mitigation activities for risks arising from potential business disruptions.	A formal risk assessment is performed on an annual basis. Company objectives are determined, and risks and mitigation strategies are identified, evaluated, and formally documented in memo form. The risk assessment includes, but is not limited to, the following areas: • Data security (company data and client data). • Potential fraud and misconduct including how management and staff might engage in inappropriate actions from the use of IT and access to information. • Regulatory, economic, and physical environment in which the company operates. • Business environment, including industry, competitors, regulatory environment, and consumers. • Potential impact of new business lines, dramatically altered business lines, acquired or divested business operations on the system of internal control, rapid growth, changing reliance on foreign geographies, and new technologies. • Management and respective attitudes and philosophies on the system of internal control. • Vendor and business partner relationships including third-party data centers. • Systems and technology environment.	Inspected the annual risk assessment documentation to determine that a formal risk assessment was performed during the review period and that company objectives, identified risks, and mitigation strategies were formally documented.	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC9.0 - COMMON CRITERIA RELATED TO RISK MITIGATION

The criteria relevant to how the entity identifies, selects and develops risk mitigation activities arising from potential business disruptions and the use of vendors and business partners.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		PROGRESS LEARNING has a documented Disaster Recovery plan and Business Continuity plan. An Incident Response plan is in place to ensure appropriate response to outages or security incidents in an organized and timely manner. Third-party enterprise monitoring applications are used to monitor system downtime and operations issues to help ensure that system downtime and performance does not exceed predefined levels. This includes monitoring of both critical network and server hardware, as well as processes and services: • System uptime and downtime • Critical performance metrics (CPU utilization, storage, etc.). Problems with critical systems are remediated as necessary.	Inspected documented Disaster Recovery plan and Business Continuity plan to determine that PROGRESS LEARNING has a documented Disaster Recovery plan and Business Continuity plan. Inspected the incident response plan to determine that a plan is in place to ensure appropriate response to outages or security incidents. Inspected the enterprise monitoring applications to determine that third-party enterprise monitoring applications are used to monitor performance criteria for critical server and network equipment. Inspected the metrics tracking reports to determine that system downtime and operations issues were monitored. Inspected a sample of Slack alerts to determine that problems with critical systems are remediated as necessary	No exceptions noted. No exceptions noted. No exceptions noted. No exceptions noted. No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC9.0 - COMMON CRITERIA RELATED TO RISK MITIGATION

The criteria relevant to how the entity identifies, selects and develops risk mitigation activities arising from potential business disruptions and the use of vendors and business partners.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC9.2	The entity assesses and manages risks associated with vendors and business partners.	Security monitoring applications and manual reviews are utilized to monitor and analyze the in-scope systems for possible or actual security breaches. (i.e., Security Information and Event Management)	Inspected the monitoring system reports, tickets, and e-mail notifications sent to the information security manager during the review period to determine that the commercial network monitoring tool monitored the network ID/PS, analyzed network events, and reported possible or actual network security breaches to information security personnel.	No exceptions noted.
		Management maintains a commercial general liability insurance policy with Technology Errors and Omissions Liability & Cyber coverage	Inspected insurance coverage policy declarations page to determine that management maintained a commercial general liability insurance policy with Technology Errors and Omissions Liability & Cyber coverage.	No exceptions noted.
		Procedures have been implemented to provide that confidential information is disclosed to third parties only in accordance with the entity's defined confidentiality and related security policies.	Inspected confidentiality policies and procedures related to disclosure to third parties to determine that confidential information is disclosed to third parties only in accordance with the entity's defined confidentiality and related security policies.	No exceptions noted.
		Procedures have been implemented to obtain assurance or representation that the policies of third parties to whom information is transferred are in conformity with the PROGRESS LEARNING policies related to confidentiality.	Inspected confidentiality policies and procedures implemented which help to obtain assurance or representation that the policies of third parties to whom information is transferred are in conformity with	No exceptions noted.

MATRIX 1 CRITERIA COMMON TO CATEGORIES OF SECURITY AND CONFIDENTIALITY

CC9.0 - COMMON CRITERIA RELATED TO RISK MITIGATION

The criteria relevant to how the entity identifies, selects and develops risk mitigation activities arising from potential business disruptions and the use of vendors and business partners.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Prior to collecting personal information of external users, a privacy policy is provided that may include the purpose and use of the personal information, including detailed use, ability to opt-out, enhancement (enrichment), sharing, disclosure, access, security, retention, breach notification requirements, and disposal of personal information. A non-disclosure or confidentiality agreement is in place with vendors that have access to sensitive data. These agreements include confidentiality commitments applicable to that entity. Related party and vendor systems are subject to review as part of the vendor risk management process. Attestation reports (SOC 2 reports) are obtained and evaluated when available. Site visits and other procedures are performed based on the entity's vendor management guidelines.	the PROGRESS LEARNING policies related to confidentiality. Inspected policies to determine that if personal information of external users is collected, a privacy policy is provided that may include the purpose and use of the collection of their personal information, including detailed use, ability to opt-out, enhancement (enrichment), sharing, disclosure, access, security, retention, breach notification requirements, and disposal of personal information. Inspected a sample of agreements to determine that a non-disclosure or confidentiality agreement is in place with vendors that have access to sensitive data and that they include confidentiality commitments applicable to that entity. Inquired of management to determine that related party and vendor systems are subject to review as part of the vendor risk management process and that attestation reports (SOC 2 reports) are obtained and evaluated when available and/or site visits and other procedures are performed based on the entity's vendor management guidelines.	No exceptions noted. No exceptions noted. No exceptions noted.

MATRIX 2 ADDITIONAL CRITERIA FOR CATEGORY OF CONFIDENTIALITY

Confidentiality Category and Criteria Table

The confidentiality category refers to the entity's ability to protect information designated as confidential from its collection or creation through its final disposition and removal from the entity's control in accordance with management's objectives.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
C1.1	The entity identifies and maintains confidential information to meet the entity's objectives related to confidentiality.	Policies and procedures are in place to communicate retention periods for confidential information maintained by PROGRESS LEARNING. Procedures are in place to: - Delete confidential information in accordance with specific retention requirements. - Delete backup information in accordance with defined schedules. - Require approval for confidential information to be retained beyond its retention period. - Review annually information marked for retention.	Inspected PROGRESS LEARNING's retention policies for confidential information to determine that the policies included procedures to: - Delete confidential information in accordance with specific retention requirements. - Delete backup information in accordance with defined schedules. - Require approval for confidential information to be retained beyond its retention period. - Review annually information marked for retention.	No exceptions noted.
		Policies and procedures are in place for classifying data based on its criticality and sensitivity and that classification is one of many factors used to define protection requirements, access rights and restrictions, and retention and destruction requirements.	Inspected the policies and procedures to determine that data classification, protection requirements, access rights, access restrictions, and retention and destruction policies were established.	No exceptions noted.
		Data is retained and disposed of in accordance with contractual obligations and applicable laws and regulations. Data up for disposal is rendered unreadable.	Inspected the data retention and destruction policies to determine that data was retained and disposed of in accordance with contractual obligations and applicable laws and regulations.	No exceptions noted.

MATRIX 2 ADDITIONAL CRITERIA FOR CATEGORY OF CONFIDENTIALITY

Confidentiality Category and Criteria Table

The confidentiality category refers to the entity's ability to protect information designated as confidential from its collection or creation through its final disposition and removal from the entity's control in accordance with management's objectives.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		Users are assigned to pre-defined roles and access rights within all PROGRESS LEARNING systems: • Access to sensitive production server directories and files is restricted based on job responsibilities. • Users are granted variable access rights according to a rights authorization methodology. • Access to systems is granted on a "least privilege" basis, with employees acquiring access only to those systems necessary to perform their job functions.	Inquired of management to determine that data up for disposal was rendered unreadable. Inquired of management to determine that users are assigned to pre-defined roles and access rights within all PROGRESS LEARNING production systems and that variable rights are assigned based on job responsibilities and least privilege. Inspected the access rights listing to determine that users are assigned to variable, pre-defined roles and access rights within all PROGRESS LEARNING production systems.	No exceptions noted. No exceptions noted. No exceptions noted.

MATRIX 2 ADDITIONAL CRITERIA FOR CATEGORY OF CONFIDENTIALITY

Confidentiality Category and Criteria Table

The confidentiality category refers to the entity's ability to protect information designated as confidential from its collection or creation through its final disposition and removal from the entity's control in accordance with management's objectives.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
C1.2	The entity disposes of confidential information to meet the entity's objectives related to confidentiality.	Policies and procedures are in place to communicate PROGRESS LEARNING's destruction policy for confidential information and various media. The entity: - locates and removes or redacts specified confidential information as required. - regularly and systematically destroys, erases, or makes anonymous confidential information that is no longer required for the purposes identified in its confidentiality commitments or system requirements. - erases or destroys records in accordance with the retention policies, regardless of the method of storage (for example, electronic, optical media, or paper based). - disposes of original, archived, backup, and ad hoc or personal copies of records in accordance with its destruction policies. - documents the disposal of confidential information. PROGRESS LEARNING documents the disposal of confidential information.	Inspected the destruction policy to determine that policies and procedures are in place to communicate PROGRESS LEARNING's destruction policy for confidential information and various media. Inspected documentation to determine that the entity documents the disposal of confidential information.	No exceptions noted. No exceptions noted.

MATRIX 2 ADDITIONAL CRITERIA FOR CATEGORY OF CONFIDENTIALITY

Confidentiality Category and Criteria Table

The confidentiality category refers to the entity's ability to protect information designated as confidential from its collection or creation through its final disposition and removal from the entity's control in accordance with management's objectives.

Control Point	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
		PROGRESS LEARNING contacts the manufacturer or an authorized recycling service provider to arrange for the proper recycling or disposal of a decommissioned device. PROGRESS LEARNING follows the manufacturer's guidelines or applicable regulations for the recycling or disposal of electronic devices. Data is retained and disposed of in accordance with contractual obligations and applicable laws and regulations. Data up for disposal is rendered unreadable.	Inquired of management to determine that PROGRESS LEARNING contacts the manufacturer or an authorized recycling service provider to arrange for the proper recycling or disposal of a decommissioned device and follows the manufacturer's guidelines or applicable regulations for the recycling or disposal of electronic devices. Inspected the data retention and destruction policies to determine that data was retained and disposed of in accordance with contractual obligations and applicable laws and regulations. Inquired of management to determine that data up for disposal was rendered unreadable.	No exceptions noted. No exceptions noted. No exceptions noted.

END OF REPORT